كورس عملي للمبتدئين والخريجين

كيف تبدأ في GRC

الحوكمة والمخاطر والامتثال من الصفر: المفاهيم، والأطر، والشهادات، ثم السيرة الذاتية ولينكدإن والمقابلة.

9 وحدات | خريطة شهادات | نماذج سيرة ولينكدإن | خطة 90 يوماً

G الحوكمة
من يقرر، وبأي قواعد

R المخاطر
ما الذي قد يحدث، وماذا نفعل

C الامتثال
هل نلتزم، وكيف نثبت

خريطة الكورس: تسع وحدات من الفكرة إلى الوظيفة

01
ما هو GRC؟
الفكرة، والأدوار، ويوم المختص.

02
الأساس التقني
الهويات، والشبكات، والسحابة، والحماية، والتغيير.

03
المفاهيم الأساسية
المخاطر، والضوابط، والوثائق، والأدلة، والمؤشرات.

04
الأطر والمعايير
العالمية والسعودية، والانطباق، والمواءمة.

05
الشهادات
المستويات، والتكلفة، وكيف تختار.

06
خطة البداية
90 يوماً ومشاريع تبني خبرتك.

07
السيرة الذاتية
بنية واضحة وإنجازات تُقرأ.

08
لينكدإن
ملف يجده مسؤول التوظيف.

09
المقابلة والخطوة التالية
أسئلة شائعة وقائمة تحقق.

— الوحدات 01 إلى 05: المعرفة — الوحدات 06 إلى 09: الوصول إلى الوظيفة

لمن هذا الكورس، وماذا ستملك في نهايته

لمن؟

خريج جديد بلا خبرة
من أي تخصص: حاسب، أو نظم، أو إدارة، أو قانون، أو محاسبة.

موظف تقنية يريد التحول
دعم فني، أو شبكات، أو تطوير، ويريد مساراً إدارياً تقنياً.

مختص تدقيق أو قانون أو جودة
يملك نصف المهارة، ويحتاج لغة الأمن السيبراني.

ستخرج بستة أشياء

- خريطة شهادات مناسبة لوضعك
- خطة 90 يوماً مكتوبة
- مشروعان في ملف أعمال
- سيرة ذاتية تقرؤها أنظمة الفرز
- ملف لينكدإن مكتمل
- إجابات جاهزة لأسئلة المقابلة

01 ما هو GRC؟

قبل الشهادات والسيرة الذاتية: افهم ما الذي يفعله مختص الحوكمة والمخاطر والامتثال، ولماذا تحتاجه كل جهة.

التعريف | لماذا تحتاجه الجهات | الفرق عن الأدوار التقنية | يوم في العمل | أربع خرافات

ثلاث كلمات، وسؤال لكل منها

Governance

الحوكمة

من يقرر، وبأي قواعد، وكيف نتابع التنفيذ؟

ما تنتجه

استراتيجية، وسياسات معتمدة، ولجنة إشرافية، وأدوار ومسؤوليات.

Risk

المخاطر

ما الذي قد يضرنا، وما احتماله وأثره، وماذا نفعل حياله؟

ما تنتجه

تقييم مخاطر، وسجل مخاطر، وخطط معالجة، وشهية للمخاطر.

Compliance

الامتثال

هل نلتزم بالأنظمة والمعايير وسياساتنا، وكيف نثبت ذلك؟

ما تنتجه

تقييم فجوات، وسجل أدلة، وتقارير امتثال، ومتابعة ملاحظات التدقيق.

الحوكمة تضع القواعد، والمخاطر تحدد الأولويات، والامتثال يثبت التطبيق. قوة GRC في ربط الثلاثة معاً.

لماذا تحتاج كل جهة من يعمل في GRC؟

1
أنظمة ملزمة

الجهات المشمولة ملزمة بضوابط وتشريعات، مثل ضوابط الهيئة الوطنية للأمن السيبراني ونظام حماية البيانات الشخصية. أحدٌ ما يجب أن يحوّل النص إلى تطبيق.

2
موارد محدودة

لا تستطيع جهة أن تحمي كل شيء بالقدر نفسه. تقييم المخاطر يحدد أين تُصرف الميزانية والجهد أولاً.

3
ثقة تحتاج دليلاً

الجهات الرقابية والعملاء والشركاء يطلبون إثباتاً لا وعداً: سياسات معتمدة، وأدلة تطبيق، وتقارير تدقيق.

أين يقع GRC بين أدوار الأمن السيبراني

الدور	السؤال الذي يجيب عنه	يوم العمل	المهارات الأهم
GRC	هل نحمي ما يهم، وهل نلتزم ونثبت؟	تقييم فجوات، وسجل مخاطر، وسياسات، ومتابعة أدلة	الكتابة، والتحليل، وفهم الأطر، والتواصل
مركز العمليات	هل يحدث هجوم الآن؟	فرز التنبيهات، والتحقيق، والتصعيد	الشبكات، والسجلات، والتحليل السريع
اختبار الاختراق	كيف يمكن اختراقنا؟	اختبار الأنظمة واكتشاف الثغرات وكتابة التقارير	الأنظمة، والبرمجة، والتفكير الهجومي
هندسة الأمن	كيف نبني الحماية؟	تصميم الضوابط التقنية وتشغيلها	البنية التحتية، والسحابة، والأتمتة

مختص GRC لا ينفذ الضوابط التقنية بنفسه غالباً، لكنه يجب أن يفهمها بما يكفي ليسأل الأسئلة الصحيحة ويقرأ الدليل.

يوم في عمل محلل GRC مبتدئ

08:00 البريد وطلبات الأدلة: ثلاث إدارات أرسلت ملفات، وواحدة تأخرت.

09:00 اجتماع قصير مع تقنية المعلومات لمتابعة خطة معالجة ثغرات.

10:30 تحديث سجل المخاطر بخطر جديد من مشروع تطبيق.

12:00 مراجعة دليل: هل تكفي لقطة الإعداد، أم نطلب سجلات؟

14:00 مسودة إجراء لمراجعة الصلاحيات دورياً.

15:30 شريحتان لتقرير اللجنة: المؤشرات والفجوات.

الأدوات: Excel وWord وPowerPoint، ونظام التذاكر، وأحياناً منصة GRC.

من تعمل معهم: التقنية، والموارد البشرية، والمشتريات، والقانونية، والإدارة.

مثال توضيحي؛ اليوم الفعلي يختلف حسب الجهة وحجمها وموسم التقييم.

أربع خرافات تؤخر البداية

~~«GRC أوراق وسياسات فقط»~~

السياسة بداية العمل لا نهايته. الجزء الأكبر هو التحقق من تطبيقها: أدلة، ومقابلات، وأنظمة.

~~«لا يحتاج أي معرفة تقنية»~~

تحتاج أساسيات تكفي لتسأل وتفهم الدليل: الشبكات، والهويات، والسجلات، والسحابة.

~~«لا يدخله إلا أصحاب الخبرة الطويلة»~~

توجد وظائف مبتدئة مثل محلل أو مساعد امتثال، والمشاريع الشخصية تعوض جزءاً من الخبرة.

~~«تكفي شهادة واحدة»~~

الشهادة تفتح باب المقابلة. ما يقنع المقابِل هو أن تشرح مثالاً عملياً بلغتك.

02 الأساس التقني

لا تحتاج أن تكون مهندساً، لكنك تحتاج أن تفهم ما تقيّمه. ستة موضوعات قصيرة، ولكل مفهوم أربعة أسئلة.

الأسئلة الأربعة
الهويات والصلاحيات
الدليل المركزي
الشبكات والسجلات
السحابة
الحماية
التطبيقات والتغيير
تمرين وإجابة

أربعة أسئلة لكل مفهوم تقني

ما هو؟

تعريف بجملة، بلا تفاصيل إعداد.

مثال: MFA: عامل ثانٍ مع كلمة المرور.

←

ما الخطر؟

ما الذي قد يحدث لو غاب أو ضعف؟

مثال: كلمة مرور مسروقة تكفي للدخول.

←

ما الضابط؟

ما الذي يعالج الخطر، ومن أي مرجع؟

مثال: MFA إلزامي للدخول عن بعد: ECC 2-2-3-2.

←

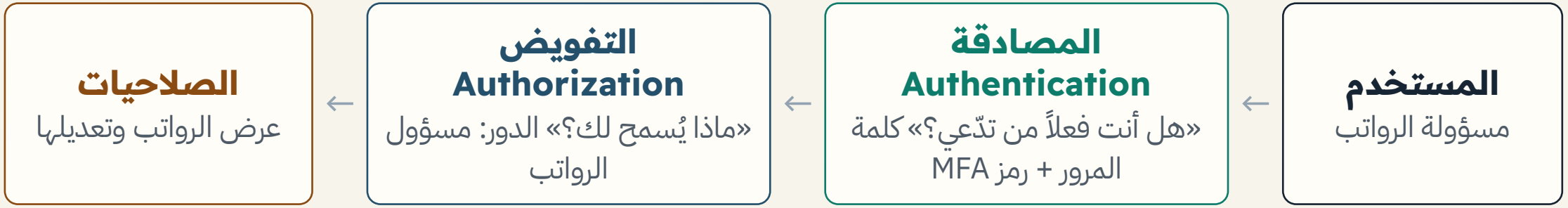
ما الدليل؟

ما الذي ستطلبه لتتأكد أنه يعمل؟

مثال: إعداد السياسة، وسجل الدخول بطريقة التحقق.

⚠ الأمثلة في هذه الوحدة من شركة توصيل افتراضية: تطبيق لتتبع الشحنات، ونظام سحابي للرواتب، وبريد سحابي، ومورد خارجي للدعم.

الهويات: من أنت؟ وماذا يُسمح لك أن تفعل؟



حساب عادي

يستخدم النظام في عمله اليومي.

مثال: حساب مسؤولة الرواتب.

حساب إداري (صلاحيات هامة)

يغيّر الإعدادات وصلاحيات الآخرين. أخطر ما يُسرق.

مثال: حساب «مدير النظام» في نظام الرواتب.

RBAC: الصلاحية للدور

تُعطى الصلاحيات للدور لا للشخص. يتغير الدور فتتغير الصلاحيات.

مثال: موظف انتقل من الموارد البشرية إلى العمليات.

الهويات بالأسئلة الأربعة

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
الحساب الإداري: يغيّر الإعدادات وصلاحيات الآخرين.	سرقته سيطرة على النظام كله.	حسابات إدارية بأسماء أصحابها وتُدار صلاحياتها · ECC 2-2-3-4	قائمة الحسابات الإدارية ومالكيها، وسجل استخدامها.
MFA: عامل ثانٍ مع كلمة المرور.	كلمة مرور مسروقة تكفي للدخول.	MFA للدخول عن بعد وللحسابات الهامة · ECC 2-2-3-2	إعداد السياسة وتاريخه، وسجل الدخول بطريقة التحقق.
RBAC وأقل صلاحية: صلاحيات حسب الدور، وبقدر الحاجة.	صلاحيات زائدة تبقى بعد تغيير الدور.	أدوار معتمدة ومراجعة دورية · ECC 2-2-3-3 و2-2-3-5	مصفوفة الأدوار، وملف المراجعة المعتمد.
فصل المهام: لا يكمل شخص واحد عملية حساسة وحده.	من يعدّل الحساب البنكي ويعتمد المسير قد يختلس.	فصل الإدخال عن الاعتماد، وموافقة ثانية.	تقرير بمن يجمع دورين متعارضين.

الدليل المركزي: Active Directory وLDAP



LDAP: الطريقة التي تسأل بها الأنظمة الدليل: من هذا المستخدم؟ وإلى أي مجموعة ينتمي؟ لا تحتاج أكثر من هذا.

الخطر

حساب مغادر نشط يفتح كل ما يرتبط بالدليل، ومجموعة إدارية متضخمة.

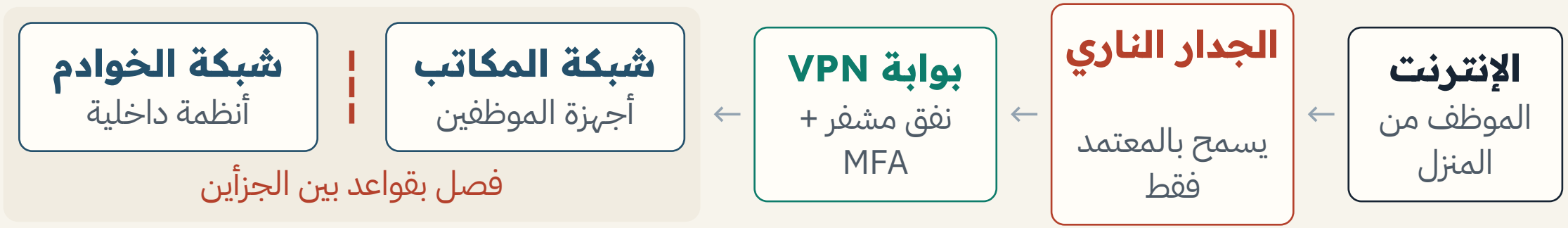
الضابط

ربط الدليل بإجراء المغادرين، ومراجعة المجموعات الإدارية.

الدليل

الحسابات المعطلة مقابل قائمة المغادرين، وأعضاء المجموعات الإدارية.

الشبكات: من أين يدخل الاتصال، وأين يُسجَّل؟



السجلات: الجدار الناري وبوابة VPN والخوادم تسجل من دخل ومتى. بلا سجلات لا اكتشاف ولا تحقيق.

الشبكات بالأسئلة الأربعة

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
الجدار الناري: يسمح بالاتصالات المعتمدة فقط.	منفذ مفتوح بلا حاجة باب للمهاجم.	قواعد بمالك وسبب، وتقييد المنافذ · ECC 2-5-3-5	قائمة القواعد، وتاريخ آخر مراجعة.
VPN: نفق مشفر إلى الشبكة من الخارج.	كلمة مرور مسروقة تفتح الشبكة.	MFA ومجموعة محددة من المستخدمين · ECC 2-2-3-2	إعداد البوابة، وسجل الاتصالات.
فصل الشبكات: أجزاء بقواعد بينها.	اختراق جهاز واحد يصل إلى الخوادم.	فصل بالجدار الناري، والإنتاج عن الاختبار · ECC 2-5-3-1 و2-5-3-2	مخطط الشبكة، وقواعد العبور.
السجلات: من دخل، ومتى، وماذا فعل.	هجوم لا يُكتشف ولا يُحقق فيه.	للأصول المهمة والدخول عن بعد، وحفظ 12 شهراً · ECC 2-12-3	إعداد التسجيل، وعينة من الفترة.

السحابة: من المسؤول عن ماذا؟

الطبقة	IaaS · خادم تطبيق التتبع	PaaS · منصة لتشغيل تطبيق	SaaS · الرواتب والبريد
البيانات وتصنيفها	**الجهة**	**الجهة**	**الجهة**
الحسابات والصلاحيات	**الجهة**	**الجهة**	**الجهة**
التطبيق	**الجهة**	**الجهة**	المزود
نظام التشغيل والتحديثات	**الجهة**	المزود	المزود
الخوادم والشبكة والمراكز	المزود	المزود	المزود

الخطر

أن تفترض الجهة أن المزود يحمي كل شيء.

الضابط

مسؤوليات مكتوبة في العقد، وحماية البيانات وإعادتها عند الإنهاء (ECC 4-2-3).

الدليل

العقد وملحق المسؤوليات، وتقارير المزود، وإعداد الحسابات من جهة الشركة.

التقسيم الدقيق في عقد كل مزود ووثائقه. لكن البيانات والحسابات تبقى مسؤولية الجهة في كل النماذج.

الحماية: أربعة ضوابط ستسأل عنها كثيراً

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
الثغرات والتحديثات: فحص دوري، وتحديث حسب الخطورة.	ثغرة معروفة يستغلها مهاجم.	معالجة بمهل حسب الخطورة، واختبار قبل الإنتاج · ECC 2-10-3	تقرير الفحص، والثغرات المفتوحة بأعمارها.
التشفير: بيانات لا تُقرأ بلا مفتاح.	جهاز مسروق يكشف البيانات.	تشفير المخزن والمنقول حسب التصنيف · ECC 2-8-3	تقرير حالة التشفير للأجهزة.
النسخ الاحتياطي: نسخ دورية تُستعاد عند الفقد.	نسخ لا تُستعاد عند الحاجة.	نطاق للأصول المهمة، واختبار دوري للاستعادة · ECC 2-9-3	تقرير المهام، ومحضر اختبار استعادة.
DLP: يكتشف خروج البيانات الحساسة ويمنعه.	ملفات الرواتب تُرسل إلى بريد خارجي.	تصنيف البيانات، ثم قواعد منع ضمن ECC 2-7 ·	القواعد المفعلة، وتقرير التنبيهات.

التطبيقات والتغيير: من التطوير إلى الإنتاج

التطوير Dev
يُكتب الكود · بيانات وهمية

←

الاختبار Test
يُجرَّب التغيير · بيانات غير حقيقية

←

الإنتاج Prod
يخدم العملاء · بيانات حقيقية

إدارة التغيير: كل تغيير على الإنتاج يمر بست خطوات

طلب	تقييم الأثر	اعتماد	اختبار	تنفيذ	مراجعة

مثال يكشفه GRC: سجل التغييرات في بوابة VPN يبين إنشاء استثناء من MFA بعد تفعيله بدقائق، بلا طلب تغيير ولا موافقة.

التطبيقات بالأسئلة الأربعة

المفهوم: ما هو؟	ما الخطر؟	الضابط المناسب	الدليل الذي تطلبه
فصل البيئات: التطوير والاختبار والإنتاج منفصلة.	تغيير غير مختبر يعطل الإنتاج.	فصل الإنتاج، وبيانات غير حقيقية للاختبار · ECC 2-5-3-2	مخطط البيئات، ومن يصل إلى كل بيئة.
إدارة التغيير: كل تغيير يُطلب ويُعتمد ويُختبر.	تغيير غير معتمد يفتح ثغرة.	إجراء تغيير، ومراجعة الإعداد الآمن قبل الإطلاق · ECC 1-6-2	تذاكر بموافقاتها، ومطابقتها بسجل التغييرات.
التطوير الآمن: الأمن جزء من كتابة الكود.	ثغرة في الكود تكشف بيانات العملاء.	كود آمن، ومكتبات موثوقة، واختبار قبل الإطلاق · ECC 1-6-3	المعيار، ونتائج اختبار الأمن.

تمرين: المفهوم والخطر والضابط والدليل

لكل موقف: ما المفهوم التقني؟ ما الخطر؟ ما الضابط المناسب؟ وما الدليل الذي ستطلبه؟ 10 دقائق.

#	الموقف	المفهوم والخطر	الضابط والدليل
1	في نظام الرواتب، يستطيع موظفان في الموارد البشرية تعديل الحساب البنكي للموظف واعتماد مسير الرواتب كليهما.		
2	طُبّق تحديث على خادم تطبيق التتبع مساء خميس مباشرة، دون طلب تغيير ولا اختبار، فتوقف التتبع ساعتين.		
3	سجلات الدخول إلى البريد السحابي تُحفظ 90 يوماً فقط، ولا أحد يراجعها.		

الإجابة: المفهوم والخطر والضابط والدليل

المفهوم	الخطر	الضابط	الدليل
1. فصل المهام	موظف واحد يغيّر الحساب البنكي ثم يعتمد المسير، فيحوّل راتباً إلى حساب آخر دون أن يُكتشف.	فصل التعديل عن الاعتماد، وموافقة ثانية على تغيير الحساب البنكي، وتقرير شهري بالتغييرات.	مصفوفة الأدوار في النظام، وتقرير بمن يجمع الصلاحيتين، وعينة من تغييرات الحسابات البنكية بموافقاتها.
2. إدارة التغيير وفصل البيئات	تغيير غير مختبر يوقف خدمة يعتمد عليها العملاء، أو يفتح ثغرة.	إجراء تغيير: طلب، وتقييم أثر، واعتماد، واختبار في بيئة غير الإنتاج، ونافذة تنفيذ محددة.	تذكرة التغيير بموافقتها ونتيجة اختباره، ومطابقة سجل تغييرات الخادم بالتذاكر.
3. السجلات	حادثة قديمة لا يمكن التحقيق فيها، ودخول مشبوه لا يكتشفه أحد.	حفظ السجلات 12 شهراً على الأقل (ECC 2-12-3-5)، ومراقبة مستمرة أو مراجعة منتظمة للتنبيهات.	إعداد مدة الحفظ في الخدمة، وأقدم سجل متاح، وتقرير المراقبة أو المراجعة.

03

المفاهيم الأساسية

اللغة التي ستستخدمها كل يوم، وستُسأل عنها في كل مقابلة: المخاطر، والضوابط، والوثائق، والأدلة، والمؤشرات.

ثلاثية الأمن
مصطلحات المخاطر
الإطار الوطني
خطوات تقييم المخاطر
مكتبة التهديدات
مصفوفة المخاطر
معالجة المخاطر
مثال تقييم كامل
أنواع الضوابط
الأثر بلغة الأعمال
هرم الوثائق
كتابة سياسة من الصفر
المعيار والإجراء
خطوط الدفاع الثلاثة
أمن العاملين
الأدلة والتدقيق
فجوات الضوابط
المؤشرات والتقرير
أدوات GRC
الأطراف الخارجية
الاستمرارية والحوادث
قاموس المصطلحات

ثلاثية الأمن: ما الذي نحميه في المعلومات؟

السرية Confidentiality

لا يطّلع على المعلومة إلا المخول.

ما يهددها: تسرب ملف رواتب.
ما يحميها: الصلاحيات والتشفير.

السلامة Integrity

المعلومة صحيحة ولم تُغيَّر دون إذن.

ما يهددها: تعديل مبلغ في أمر صرف.
ما يحميها: فصل المهام والسجلات.

التوافر Availability

المعلومة والخدمة متاحتان وقت الحاجة.

ما يهدده: برمجية فدية توقف البوابة.
ما يحميه: النسخ الاحتياطي وخطط التعافي.

في كل خطر اسأل: أي الثلاثة يمس؟ الإجابة تحدد الضابط المناسب وحجم الأثر.

ستة مصطلحات للمخاطر، بمثال واحد

المثال: حاسوب محمول لموظف في المالية، عليه ملفات رواتب الموظفين.

الأصل · Asset

ما له قيمة للجهة.

الحاسوب وملفات الرواتب.

التهديد · Threat

ما قد يسبب الضرر.

سرقة الحاسوب من السيارة.

الثغرة · Vulnerability

ضعف يسهّل الضرر.

القرص غير مشفر.

الاحتمال · Likelihood

فرصة حدوث الضرر.

متوسط: الموظف يتنقل كثيراً.

الأثر · Impact

حجم الضرر إن حدث.

عالٍ: تسرب رواتب كل الموظفين.

الخطر · Risk

تهديد يستغل ثغرة في أصل.

«تسرب الرواتب بسرقة حاسوب غير مشفر».

الإطار الوطني لإدارة مخاطر الأمن السيبراني

الاسم والإصدار الإطار الوطني لإدارة مخاطر الأمن السيبراني NFCRM-1:2025، صدر 23 يوليو 2025.

على من ينطبق الجهات الحكومية وما يتبعها، وجهات القطاع الخاص التي تملك أو تشغل أو تستضيف بنية تحتية وطنية حساسة.

لغيرها تشجع الهيئة بقية الجهات على الاستفادة منه، ويمكن تبني مصفوفته طوعاً.

1 التحديد

الأصول، والثغرات، والتهديدات، والسيناريوهات، والضوابط الحالية.

← **2 التقييم**

الاحتمال والأثر بالمصفوفة، والتوثيق في السجل.

← **3 المعالجة**

قبول، أو مشاركة، أو تخفيف، أو تجنب، بخطط وأولويات.

← **4 المتابعة**

تقارير، ومراقبة الخطط، وإعادة التقييم عند التغيير.

تقييم المخاطر بالإطار الوطني: الخطوات بالترتيب

1. التحديد

6.3 الأصول وتصنيفها

6.4 الثغرات

6.5 التهديدات المحتملة

6.6 سيناريوهات المخاطر

6.7 الضوابط الحالية

6.8 مستوى الخطر المقبول

2. التقييم

6.9 الاحتمال والأثر بالمصفوفة

6.10 التوثيق في سجل المخاطر

3. المعالجة

6.11 تحديد خطط المعالجة

6.12 تقدير الخطر المتبقي

6.13 قرار المعالجة

6.14 الخطط حسب الأولوية

6.15 التنفيذ

6.16 تحديث السجل

4. المتابعة

6.17 تقارير المخاطر

6.18 معايير جمع البيانات

6.19 متابعة الخطط

6.20 إعادة التقييم دورياً وعند التغيير

متى يُجرى التقييم؟ ECC 1-5-3: في بداية المشاريع التقنية، وقبل التغييرات الكبيرة، وعند التخطيط لخدمات طرف خارجي، وقبل إطلاق خدمات ومنتجات تقنية جديدة.

مكتبة التهديدات: أربعة أنواع لمصادر التهديد

⚠ الإطار الوطني يطلب تحديد التهديدات المحتملة (الخطوة 6.5)، لكنه لا يضع مكتبة تهديدات. الجهة تبنيها بنفسها.

عدائي
Adversarial

من يقصد الضرر.

أمثلة: فرد من الخارج أو الداخل، أو مجموعة، أو منظمة كالمورد والمنافس، أو دولة.

عرضي
Accidental

خطأ بلا قصد.

أمثلة: مستخدم عادي، أو مستخدم بصلاحيات هامة كمدير النظام.

هيكلي
Structural

تعطل في التقنية نفسها.

أمثلة: أجهزة التخزين والمعالجة والاتصال، والتبريد والكهرباء، والبرمجيات.

بيئي
Environmental

ظروف خارج التقنية.

أمثلة: حريق أو فيضان أو زلزال، وانقطاع الكهرباء أو الاتصالات.

مصادر تغذي مكتبتك: حوادث الجهة نفسها، وتنبيهات الهيئة الوطنية للأمن السيبراني، وتغذيات استخبارات التهديدات (ECC 2-13-3-5)، وMITRE ATT&CK لأساليب المهاجمين، وتقرير ENISA السنوي عن التهديدات.

مكتبة التهديدات: نموذج تبدأ منه

مكتبة التهديدات · نموذج مختصر

نموذج تعليمي · بيانات افتراضية

الرمز	التهديد	النوع	الأصول المعرضة عادة	ضوابط ECC المرتبطة
T-01	التصيد لسرقة بيانات الدخول	عدائي · خارجي	البريد، وكل نظام بكلمة مرور	ECC 2-2-3-2 · 1-10-3-1
T-02	استغلال ثغرة في خدمة مكشوفة على الإنترنت	عدائي · خارجي	الخوادم والتطبيقات المكشوفة	ECC 2-10-3 · 2-3-3-3
T-03	برمجيات الفدية	عدائي · خارجي	الخوادم والبيانات	ECC 2-3-3-1 · 2-9-3
T-04	إساءة استخدام الصلاحيات من الداخل	عدائي · داخلي	الأنظمة الحساسة	ECC 2-2-3-3 · 2-2-3-4
T-05	خطأ في الإعداد من مدير نظام	عرضي	الأنظمة والخدمات السحابية	ECC 1-6-2
T-06	اختراق عبر مورد أو حسابه	عدائي · شريك	ما يصل إليه المورد	ECC 4-1-2 · 4-1-3-1
T-07	تعطل جهاز تخزين أو برمجية	هيكلي	الخوادم والتخزين	ECC 2-9-3 · 3-1-3-3
T-08	انقطاع الكهرباء أو حريق في مركز البيانات	بيئي	مركز البيانات	ECC 3-1-3-3

في السجل تكتب رمز التهديد، فتعرف كل المخاطر التي سببها التصيد مثلاً، وتحدّثها معاً حين يتغير التهديد.

مستويات الأثر في الإطار الوطني

يُقاس الأثر على السرية أو السلامة أو التوافر، ويُختار أعلى أثر بين الثلاثة.

القيمة	المستوى	الوصف في الإطار	مثال في نظام الرواتب
5	حرج	أثر كبير على الجهة لا يُحتمل، أو أثر على المستوى الوطني.	تسرب رواتب كل الموظفين وحساباتهم البنكية للعلن.
4	عالٍ	أثر كبير على الجهة.	تغيير الحسابات البنكية في نظام الرواتب، أو اطلاع مهاجم عليها.
3	متوسط	أثر ملموس على الجهة.	توقف نظام الرواتب يوماً قبل موعد الصرف.
2	منخفض	أثر طفيف على الجهة.	كشف قائمة أسماء الإدارات الداخلية.
1	منخفض جداً	لا أثر على الجهة، أو بيانات غير حساسة.	كشف معلومة منشورة أصلاً على الموقع.

مستويات الاحتمال في الإطار الوطني

يُختار المستوى بأحد معيارين: الإطار الزمني، أو سهولة استغلال الثغرة. واكتب مبرر اختيارك في السجل.

القيمة	المستوى	بالإطار الزمني	أو: بسهولة استغلال الثغرة
5	شبه مؤكد	يتكرر غالباً، عدة مرات في الشهر أو في السنة.	يستغلها مهاجم غير محترف بأداة جاهزة.
4	محتمل	يحدث غالباً مرة في السنة.	يستغلها مهاجم متقدم بأدوات أو أساليب خاصة.
3	غير مرجح	قد يحدث مرة كل سنتين إلى ثلاث.	يستغلها مهاجم متقدم بشروط محددة فقط.
2	نادر	قد يحدث مرة كل 3 إلى 10 سنوات.	لا تُستغل مباشرة الآن، وقد تُستغل مستقبلاً.
1	نادر جداً	في ظروف استثنائية، أقل من مرة كل 10 إلى 20 سنة.	لا تُعد قابلة للاستغلال حالياً.

مصفوفة المخاطر في الإطار الوطني

الاحتمال ↑

الاحتمال	الأثر: منخفض جداً (1)	الأثر: منخفض (2)	الأثر: متوسط (3)	الأثر: عالٍ (4)	الأثر: حرج (5)
5 شبه مؤكد	5 منخفض	10 متوسط	15 عالٍ	20 حرج	25 حرج
4 محتمل	4 منخفض	8 متوسط	12 متوسط	16 عالٍ	20 حرج
3 غير مرجح	3 منخفض	6 منخفض	9 متوسط	12 متوسط	15 عالٍ
2 نادر	2 منخفض جداً	4 منخفض	6 منخفض	8 متوسط	10 متوسط
1 نادر جداً	1 منخفض جداً	2 منخفض جداً	3 منخفض	4 منخفض	5 منخفض

الأثر يزداد نحو اليمين →

مستوى الخطر = الأثر × الاحتمال

حرج	عالٍ	متوسط	منخفض	منخفض جداً
20–25	15–19	8–14	3–7	1–2

مثال الحاسوب المحمول: احتمال 3 (غير مرجح) × أثر 4 (عالٍ) = 12، أي متوسط.

الجهات الملزمة بالإطار تبلّغ الهيئة فوراً عن المخاطر العالية والحرجة عبر منصة «حصين» (البند 5.5).

أربعة خيارات لمعالجة الخطر

التخفيف · Mitigate

ضوابط تقلل الاحتمال أو الأثر.

تشفير القرص. الأكثر استخداماً.

التجنب · Avoid

إيقاف النشاط الذي يسبب الخطر.

منع حفظ ملفات الرواتب على الأجهزة المحمولة.

النقل · Transfer

تحميل جزء من الأثر المالي لطرف آخر.

تأمين أو عقد خدمة. المسؤولية والسمعة لا تنتقلان.

القبول · Accept

قرار موثق ممن يملك الصلاحية.

قبول مؤقت لخادم قديم مع خطة استبداله.

الخطر المتأصل

قبل الضوابط: 3 × 4 = 12

الخطر المتبقي

بعد التشفير: 3 × 1 = 3

شهية المخاطر

المستوى الذي تقبله الإدارة. ما فوقه يُعالج.

مثال محلول (1 من 3): التحديد

الأصل وتصنيفه (6.3)	نظام الموارد البشرية والرواتب السحابي. بيانات الرواتب والحسابات البنكية: حساسة.
الثغرات (6.4)	الدخول الإداري بكلمة مرور فقط، بلا تحقق متعدد العوامل. وحسابات مغادرين ما زالت نشطة.
التهديد (6.5)	T-01 التصيد لسرقة بيانات الدخول، من مكتبة التهديدات. ومحاولة تصيد ناجحة واحدة في الشركة العام الماضي.
السيناريو (6.6)	مهاجم يسرق بيانات دخول مدير النظام برسالة تصيد، ويدخل بلا عامل ثانٍ، فيغيّر الحسابات البنكية أو يسرّب بيانات الرواتب.
الضوابط الحالية (6.7)	كلمة مرور 8 أحرف، وتوعية سنوية عامة. لا MFA، ولا مراجعة لسجل دخول المدير.
المستوى المقبول (6.8)	قرار الشركة: المنخفض يقبله مالك الخطر، والمتوسط يقبله الرئيس التنفيذي بقرار موثق، والعالي والحرج تُعالج إلزامياً.

صيغة الخطر R-IAM-01: بسبب الدخول الإداري بلا MFA، قد يُسرق حساب المدير بالتصيد، مما يؤدي إلى تغيير الرواتب أو تسرب بياناتها.

مثال محلول (2 من 3): التقييم والمعالجة

	القيمة	المبرر
الاحتمال	4 · محتمل	التصيد نجح مرة في السنة الماضية (الإطار الزمني).
الأثر	4 · عالٍ	تغيير الحسابات البنكية أو كشفها: أثر كبير على الجهة (السلامة والسرية).
الخطر المتأصل	**16 · عالٍ**	فوق المقبول، فالمعالجة إلزامية.
المعالجة: تخفيف	MFA للحسابات الهامة (2-2-3-2)، وحساب إداري منفصل (2-2-3-4)، وتسجيل دخول المدير (2-2-3-12).	
الخطر المتبقي	**8 · متوسط**	الاحتمال 2 · نادر: الثغرة لم تعد تُستغل مباشرة. الأثر يبقى 4.
القرار	قبول المتبقي	يقبله الرئيس التنفيذي بقرار موثق، ويُراجع بعد 6 أشهر.

الاحتمال ↑

5 شبه مؤكد	5 منخفض	10 متوسط	15 عالٍ	20 حرج	25 حرج
4 محتمل	4 منخفض	8 متوسط	12 متوسط	16 عالٍ	20 حرج
3 غير مرجح	3 منخفض	6 منخفض	9 متوسط	12 متوسط	15 عالٍ
2 نادر	2 منخفض جداً	4 منخفض	6 منخفض	8 متوسط	10 متوسط
1 نادر جداً	1 منخفض جداً	2 منخفض جداً	3 منخفض	4 منخفض	5 منخفض
	1 منخفض جداً	2 منخفض	3 متوسط	4 عالٍ	5 حرج

الأثر يزداد نحو اليمين →

مثال محلول (3 من 3): سجل المخاطر

سجل مخاطر الأمن السيبراني · نموذج — نموذج تعليمي · بيانات افتراضية

الرمز	الأصل	التهديد	الثغرة	الضوابط الحالية	ا × أ	المتأصل	المعالجة	المالك	الموعد	المتبقي
R-IAM-01	نظام الرواتب	T-01	دخول إداري بلا MFA	كلمة مرور، توعية	4 × 4	16 عالٍ	تخفيف: MFA، حساب منفصل، سجلات	مدير التقنية	30 يوماً	8 متوسط
R-IAM-02	نظام الرواتب	T-04	حسابات مغادرين نشطة	إلغاء يدوي عند الطلب	4 × 3	12 متوسط	تخفيف: ربط المغادرة، مراجعة دورية	مديرة الموارد البشرية	60 يوماً	4 منخفض

⚠ الخطوة 6.10 توثق التقييم، والخطوة 6.16 تضيف المعالجة والمتبقي. والخطران هما مدخل السياسة في الشرائح التالية.

الضوابط: طبيعتها ووظيفتها

الطبيعة	وقائي: يمنع الحدوث	كشفي: يكتشف ما حدث	تصحيحي: يعالج الأثر
إداري	السياسات، والتوعية	مراجعة الصلاحيات الدورية، والتدقيق	خطة الاستجابة للحوادث
تقني	التحقق متعدد العوامل، والتشفير، والجدار الناري	منصة سجلات الأحداث، وكشف التسلل	الاستعادة من النسخ، والتحديثات
مادي	البطاقات، والأقفال	كاميرات المراقبة، والحراسة	إطفاء الحريق، وموقع التعافي

الضابط الواحد قد يؤدي أكثر من وظيفة: منصة الحماية تمنع الملف الضار وتسجل المحاولة.

الضابط الجيد يجمع الأنواع: وقائي يقلل الحدوث، وكشفي يرى ما فات، وتصحيحي يعيد الوضع.

مثال محلول: من هدف العمل إلى قرار الإدارة

أهداف شركة توصيل يخدمها GRC (مثال افتراضي):

استمرار التوصيل: تتبع الشحنات متاح للمتاجر والعملاء.	حماية بيانات العملاء: بيانات المستلمين لا تتسرب.	صحة الرواتب: رواتب صحيحة إلى الحسابات الصحيحة في موعدها.	الالتزام بالعقود: ما وعدت به الشركة عملاءها وموردیها.

1. هدف العمل	استمرار تتبع الشحنات، والوفاء بالتزام عقود المتاجر: إتاحة 99% شهرياً.
2. الأصل الداعم	خادم تطبيق التتبع السحابي، ويديره مورد دعم خارجي.
3. الخطر	بسبب تأخر ترقيع الثغرات الحرجة في خادم مكشوف على الإنترنت، قد يُستغل فيتوقف التتبع أو تتسرب بيانات العملاء. التقييم: 4 × 4 = 16 · عالٍ.
4. الضابط	فحص شهري للثغرات، وترقيع الحرجة خلال 14 يوماً، ومهلة الترقيع بند في عقد المورد.
5. المالك	مالك الخطر: مدير تقنية المعلومات. المنفذ: المورد تحت إشرافه.
6. المؤشر	KRI: الثغرات الحرجة المفتوحة أكثر من 14 يوماً. آخر قياس: 3. الحد: صفر.
7. القرار المطلوب	اعتماد كلفة ترقيع عاجل الآن، وإضافة المهلة إلى العقد عند تجديده.

صياغة الأثر بلغة الأعمال

صِف الأثر بواحد أو أكثر من:

توقف خدمة | تأخير عمليات | تسرب بيانات | تكلفة | التزام تعاقدي

بلغة تقنية	بلغة الأعمال	نوع الأثر
ثغرة حرجة غير مرقعة في خادم التتبع.	قد يتوقف تتبع الشحنات لكل المتاجر، فتتأخر التسليمات وتكثر الشكاوى.	توقف خدمة
حسابان لمغادرين نشطان في نظام الرواتب.	شخصان خارج الشركة قد يطلعان على رواتب الموظفين وحساباتهم البنكية.	تسرب بيانات
النسخ يومي، والحد المقبول لفقد البيانات 4 ساعات.	قد نفقد يوم عمل من تعديلات الرواتب، فيتأخر الصرف أو يخطئ.	تأخير عمليات
عقد المورد بلا بند للإبلاغ عن الحوادث.	قد لا نعلم بتسرب في الوقت، فنتأخر في إبلاغ العملاء والجهة المختصة.	التزام تعاقدي

المدير لا يقرر بناءً على «ثغرة حرجة»، بل على ما تعنيه لخدمته وعملائه وتكلفته والتزاماته.

هرم الوثائق: من «لماذا» إلى «كيف»

مثال واحد على أربعة مستويات: كلمات المرور. القيم أمثلة توضيحية، وكل جهة تحددها في وثائقها.

السياسة
ماذا ولماذا · يعتمدها صاحب الصلاحية

«يكون الدخول إلى الأنظمة بهوية فردية وكلمة مرور قوية، والتحقق متعدد العوامل إلزامي للدخول عن بعد.»

المعيار
قيم ملزمة قابلة للقياس

«12 حرفاً على الأقل، ويُقفل الحساب بعد 5 محاولات فاشلة.»

الإجراء
خطوات: من يفعل ماذا ومتى

«لإعادة تعيين كلمة المرور: يتحقق الدعم الفني من هوية الموظف بطريقة معتمدة، ثم يرسل رابطاً مؤقتاً، ويسجل الطلب.»

الإرشاد
توصيات غير ملزمة

«يُنصح باستخدام عبارة مرور من عدة كلمات، ومدير كلمات المرور المعتمد في الجهة.»

مكونات السياسة: سياسة واحدة كاملة

سياسة

نموذج تعليمي · بيانات افتراضية

سياسة إدارة هويات الدخول والصلاحيات

الرمز: POL-IAM-01 الإصدار: 1.0 الاعتماد: الرئيس التنفيذي المالك: إدارة الأمن السيبراني

1. الغرض	حماية الوصول إلى الأنظمة والبيانات، وتقييده بقدر الحاجة.
2. النطاق	كل أنظمة الشركة وكل الحسابات، ومنها الموردون.
4. الأدوار	مالك النظام يعتمد، وتقنية المعلومات تنفذ، والأمن السيبراني يتابع.
5. البنود	5.1 هوية فردية · 5.3 5.6 · MFA مراجعة دورية · 5.7 المغادرة.
6. الاستثناءات	بموافقة موثقة ومدة محددة، وتُسجل في سجل المخاطر.
9. الاعتماد والمراجعة	يعتمدها الرئيس التنفيذي، وتُراجع سنوياً أو عند تغير المتطلبات.

1. **لماذا ولمن؟**
   الغرض والنطاق يحددان ما تغطيه السياسة.
2. **من يفعل ماذا؟**
   المسؤوليات بالوظيفة، والمتطلبات ما يُطلب دليله.
3. **متى نخرج عنها؟**
   استثناء بموافقة ومدة، لا بقرار فردي.
4. **من يعتمد، ومتى تُراجع؟**
   إصدار وتاريخ وصاحب صلاحية.

كيف تكتب سياسة من الصفر: سبع خطوات

1
اقرأ المتطلبات
ECC 1-3 لكل السياسات، وECC 2-2 للموضوع، وأي نظام أو عقد ينطبق. اكتب قائمة بما «يجب».

2
اجمع السياق
الأنظمة والأدوار ونتائج تقييم المخاطر: ما الذي نحميه، ومن يفعل ماذا اليوم؟

3
حدد النطاق والملكية
أي أنظمة وحسابات تشمل، ومن مالك السياسة، ومن يعتمدها.

4
اكتب البنود
بند لكل متطلب: «يجب» + من + ماذا، قابل للإثبات، ويتتبع إلى مرجعه.

5
افصل التفاصيل
الأرقام والإعدادات إلى المعيار، والخطوات إلى الإجراء (ECC 1-3-3).

6
راجع واعتمد وانشر
مراجعة أصحاب العلاقة، ثم اعتماد صاحب الصلاحية، ثم الإبلاغ (ECC 1-3-1).

7
طبّق وراجع
تطبيق يُقاس بالأدلة (1-3-2)، ومراجعة دورية أو عند تغير المتطلبات (1-3-4).

⚠ المثال في الشرائح التالية: سياسة إدارة هويات الدخول والصلاحيات (POL-IAM-01)، ثم معيارها، ثم إجراء المراجعة الدورية. الموضوع نفسه من أوله إلى دليله.

السياسة كاملة (1 من 3): الغرض والنطاق والأدوار

سياسة · POL-IAM-01

صفحة 1 من 3 نموذج تعليمي · بيانات افتراضية

سياسة إدارة هويات الدخول والصلاحيات

الإصدار 1.0 · التصنيف: داخلي · المالك: إدارة الأمن السيبراني · يعتمدها: الرئيس التنفيذي · المراجعة: سنوياً

1. الغرض

ECC 2-2

حماية الوصول المنطقي إلى الأصول المعلوماتية والتقنية للشركة، ومنع الوصول غير المصرح به، وتقييد الوصول بالقدر اللازم لأداء المهام.

2. النطاق

جميع الأنظمة والتطبيقات وقواعد البيانات والخدمات السحابية التي تملكها الشركة أو تستخدمها، وجميع الحسابات: الموظفين والمتعاقدين والموردين وحسابات الخدمة والحسابات الإدارية.

3. التعريفات

الحساب ذو الصلاحيات الهامة: حساب يغير الإعدادات أو صلاحيات الآخرين. التحقق متعدد العوامل: عاملان مستقلان أو أكثر للتحقق من الهوية. مالك النظام: من يعتمد الوصول إلى النظام ويراجعه.

4. الأدوار والمسؤوليات

ECC 1-4

الرئيس التنفيذي يعتمد السياسة. إدارة الأمن السيبراني تعدها وتتابع الالتزام بها. مالك النظام يعتمد منح الصلاحيات ومراجعتها. تقنية المعلومات تنفذ المنح والتعديل والإلغاء. الموارد البشرية تبلّغ عن الانضمام والانتقال والمغادرة. والمستخدم يحمي بيانات دخوله.

السياسة كاملة (2 من 3): بنود «يجب»

سياسة · POL-IAM-01

صفحة 2 من 3 نموذج تعليمي · بيانات افتراضية

سياسة إدارة هويات الدخول والصلاحيات

الإصدار 1.0 · التصنيف: داخلي · المالك: إدارة الأمن السيبراني · يعتمدها: الرئيس التنفيذي · المراجعة: سنوياً

5.1 الهوية الفردية — ECC 2-2-3-1

يجب أن يكون لكل مستخدم حساب فردي مرتبط بهويته. ويُمنع الحساب المشترك إلا باستثناء معتمد.

5.2 المصادقة — ECC 2-2-3-1

يجب التحقق من هوية كل مستخدم باسم مستخدم وكلمة مرور وفق المعيار STD-IAM-01 حداً أدنى.

5.3 التحقق متعدد العوامل — ECC 2-2-3-2

يجب تطبيقه للدخول عن بعد وللحسابات ذات الصلاحيات الهامة. وتُحدد العوامل وتقنياتها بناءً على تقييم أثر فشل المصادقة أو تجاوزها.

5.4 منح الصلاحيات — ECC 2-2-3-3

تُمنح بطلب موثق يعتمده مالك النظام، وفق مبادئ الحاجة إلى المعرفة والاستخدام، وأقل صلاحية، وفصل المهام.

5.5 الصلاحيات الهامة — ECC 2-2-3-4

تُدار بحسابات منفصلة عن الحساب اليومي، وتُسجَّل أنشطتها، وتُراجع دورياً.

السياسة كاملة (3 من 3): الاستثناءات والاعتماد

سياسة إدارة هويات الدخول والصلاحيات

الإصدار 1.0 · التصنيف: داخلي · المالك: إدارة الأمن السيبراني · يعتمدها: الرئيس التنفيذي · المراجعة: سنوياً

5.6 المراجعة الدورية — ECC 2-2-3-5

تُراجع الهويات وصلاحياتها دورياً وفق المعيار، ويعتمد مالك النظام النتيجة.

5.7 الانتقال والمغادرة — ECC 1-9-5

تُعدَّل الصلاحيات عند تغيير الدور، وتُراجع وتُلغى فور انتهاء العلاقة الوظيفية.

5.8 السجلات — ECC 2-12-3

تُفعَّل سجلات الأحداث للحسابات ذات الصلاحيات الهامة وللدخول عن بعد، وتُحفظ وفق المعيار.

6. الاستثناءات

بطلب موثق ومبرر، مع ضابط تعويضي ومدة محددة، باعتماد الأمن السيبراني ومالك النظام، ويُسجَّل في سجل المخاطر.

7. الالتزام — ECC 2-2-4

تراجع إدارة الأمن السيبراني تطبيق هذه السياسة دورياً، وتُعالج المخالفات وفق لوائح الشركة.

8. الوثائق المرتبطة — ECC 1-3-3

STD-IAM-01 المعيار · PRC-IAM-01 المنح والتعديل والإلغاء · PRC-IAM-03 المراجعة الدورية.

9. الاعتماد والمراجعة — ECC 1-3-1 · 1-3-4

يعتمدها الرئيس التنفيذي وتُبلَّغ للمعنيين، وتُراجع سنوياً أو عند تغير المتطلبات، وتُوثق التغييرات وتُعتمد.

المعيار: من «يجب» إلى أرقام قابلة للقياس

معيار · STD-IAM-01 · معيار هويات الدخول والصلاحيات

نموذج تعليمي · بيانات افتراضية

الموضوع	القيمة الملزمة	بند السياسة
كلمة المرور	12 حرفاً على الأقل، و16 للحسابات الهامة. لا تكرار لآخر 5 كلمات. قفل الحساب بعد 5 محاولات فاشلة لمدة 15 دقيقة.	5.2
التحقق متعدد العوامل	تطبيق مصادقة أو مفتاح أمان للدخول عن بعد. مفتاح أمان أو تطبيق مصادقة للحسابات الهامة، ولا تُعتمد الرسائل النصية لها.	5.3
الحسابات الهامة	حساب إداري منفصل لكل مدير، بلا بريد ولا تصفح. الدخول عبر أداة إدارة الصلاحيات الهامة، مع تسجيل الجلسات.	5.5
المراجعة الدورية	الحسابات الهامة كل 3 أشهر، وبقية الحسابات كل 6 أشهر. إزالة غير المبرر خلال 5 أيام عمل.	5.6
الانتقال والمغادرة	تعطيل كل الحسابات في آخر يوم عمل. إزالة صلاحيات الدور القديم خلال 3 أيام عمل من النقل.	5.7
الحسابات الخاملة والخدمة	تعطيل الحساب بعد 90 يوماً بلا استخدام. حساب الخدمة له مالك، ولا دخول تفاعلياً به.	5.1
السجلات	تسجيل دخول الحسابات الهامة والدخول عن بعد، وحفظ السجلات 12 شهراً على الأقل.	5.8 · ECC 2-12-3-5

القيم أمثلة تختارها الجهة بناءً على مخاطرها. ECC لا يحدد أغلبها، ويحدد مدة حفظ السجلات: 12 شهراً على الأقل.

الإجراء: خطوات المراجعة الدورية للصلاحيات

إجراء · PRC-IAM-03 · المراجعة الدورية للصلاحيات

نموذج تعليمي · بيانات افتراضية

#	المسؤول	الخطوة	المهلة
1	إدارة الأمن السيبراني	تصدر جدول المراجعة وتبلّغ مالكي الأنظمة.	قبل الموعد بأسبوعين
2	تقنية المعلومات	تصدّر الحسابات وصلاحياتها من النظام، بتاريخ التصدير.	3 أيام عمل
3	الموارد البشرية	تزود قائمة الموظفين النشطين والمنقولين والمغادرين في الفترة.	3 أيام عمل
4	مالك النظام	يقرر لكل حساب: يبقى، أو يُعدَّل، أو يُزال، مع المبرر.	10 أيام عمل
5	إدارة الأمن السيبراني	تطابق النتيجة بقائمة الموارد البشرية، وتكشف الحسابات اليتيمة والمشتركة والهامة غير المبررة.	3 أيام عمل
6	تقنية المعلومات	تنفذ الإزالة والتعديل بتذاكر.	5 أيام عمل (المعيار)
7	إدارة الأمن السيبراني	تتحقق بتصدير ثانٍ أن التغييرات نُفذت.	يومان
8	مالك النظام	يعتمد النتيجة النهائية، ويُحفظ الملف دليلاً.	عند الإغلاق

المخرجات والأدلة: ملف المراجعة المعتمد، وتذاكر الإزالة، والتصدير الثاني. ومؤشره (KCI): نسبة المراجعات المعتمدة في موعدها.

من الخطر إلى الدليل: جدول التتبع

الخطر	متطلب ECC	بند السياسة	المعيار	الإجراء	الدليل
R-IAM-01 · الدخول الإداري بلا MFA	ECC 2-2-3-2	5.3	عوامل الحسابات الهامة	PRC-IAM-01	إعداد السياسة، وسجل الدخول بطريقة التحقق
R-IAM-01	ECC 2-2-3-4	5.5	حساب منفصل وأداة إدارة	PRC-IAM-01	قائمة الحسابات الهامة ومالكيها
R-IAM-02 · حسابات مغادرين نشطة	ECC 1-9-5	5.7	تعطيل في آخر يوم عمل	PRC-IAM-01	قائمة المغادرين مقابل الحسابات المعطلة
R-IAM-02	ECC 2-2-3-5	5.6	كل 3 و6 أشهر	PRC-IAM-03	ملف المراجعة المعتمد، والتذاكر

اقرأ الجدول في الاتجاهين: من الخطر إلى الدليل لتبني الضوابط، ومن الدليل إلى المتطلب حين يسألك المقيّم.

المخاطر من تقييم المخاطر في الشرائح السابقة. وPRC-IAM-01 إجراء المنح والتعديل والإلغاء، لم نعرضه هنا.

قائمة تحقق للسياسة، وأخطاء شائعة

قبل أن ترسلها للاعتماد

- ✓ كل بند يتتبع إلى متطلب أو خطر.
- ✓ كل بند يبدأ بـ«يجب» ويذكر من يفعل ماذا.
- ✓ لا أرقام ولا خطوات في السياسة.
- ✓ كل بند له دليل يمكن طلبه.
- ✓ للاستثناء موافقة ومدة.
- ✓ إصدار، ومالك، واعتماد، وموعد مراجعة.

أخطاء شائعة

- ⚠ نسخ نص ECC حرفياً دون ربطه بأنظمة الجهة.
- ⚠ «يُفضّل» و«قدر الإمكان» بدل «يجب».
- ⚠ بنود بلا مالك.
- ⚠ أرقام في السياسة تتغير كل سنة.
- ⚠ سياسة معتمدة لم تُبلَّغ لأحد.
- ⚠ اعتبار السياسة دليلاً على الالتزام.

نموذج الخطوط الثلاثة: من يفعل ماذا في المخاطر؟

جهة الحوكمة (مجلس الإدارة أو صاحب الصلاحية واللجان): تحدد التوجه وتحاسب الجميع.

الخط الأول

الإدارة التشغيلية

تملك المخاطر وتطبق الضوابط يومياً.

تقنية المعلومات، وملاك الأنظمة، والموارد البشرية.

الخط الثاني · هنا يعمل GRC غالباً

المخاطر والامتثال

يضع الإطار، ويدعم، ويراقب، ويتحدى.

حوكمة الأمن السيبراني، وإدارة المخاطر، والامتثال.

الخط الثالث

المراجعة الداخلية

تأكيد مستقل لجهة الحوكمة.

لا تنفذ الضوابط ولا تصممها، لتبقى مستقلة.

من الخارج: المدقق الخارجي والجهات الرقابية يقدمون تأكيداً إضافياً.

أمن العاملين: الانضمام وتغيير الدور والمغادرة

الانضمام

بنود المسؤوليات والسرية في العقد، وتوعية عند البدء، وصلاحيات حسب الدور.

مثال: لا يحصل الموظف الجديد على حساب الرواتب قبل طلب معتمد من مديره.

الدليل: عقد موقّع، وسجل إكمال التوعية، وطلب الصلاحيات.

تغيير الدور

تُضاف صلاحيات الدور الجديد، وتُزال صلاحيات القديم في الوقت نفسه.

مثال: موظف انتقل إلى العمليات، وبقيت معه صلاحية «تعديل الرواتب» ثلاثة أشهر.

الدليل: طلب النقل، وتذكرة تعديل الصلاحيات بتاريخها.

المغادرة

مراجعة الصلاحيات وإلغاؤها مباشرة، واستعادة الأصول، وتذكير بالسرية.

مثال: الموارد البشرية تبلّغ تقنية المعلومات قبل آخر يوم عمل.

الدليل: إشعار الموارد البشرية، وتذاكر الإلغاء، ومحضر استلام الأصول.

التوعية ليست محاضرة سنوية فقط: عند الانضمام وخلال العمل، ويُقاس إكمالها.

الأدلة والتدقيق: كيف نثبت أن الضابط يعمل؟

أنواع الأدلة

- وثيقة معتمدة: سياسة، أو محضر
- إعداد من النظام: تصدير مؤرخ
- سجلات وتقارير: ما حدث فعلاً
- مقابلة أو ملاحظة مباشرة

الدليل الجيد

مرتبط بالضابط، ومؤرخ ضمن الفترة، ومن مصدره، ويغطي المجتمع كله أو عينة مبررة.

عناصر الملاحظة المكتوبة

العنصر	مثال
الوضع القائم	13 حساباً مميزاً بلا تحقق متعدد العوامل
المعيار	السياسة تشترطه لكل الحسابات المميزة
السبب	لا حصر دوري للحسابات المميزة
الأثر	كلمة مرور مسروقة تكفي للسيطرة
التوصية	إلزام فوري وحصر شهري، بمالك وموعد

التصميم والتنفيذ والتشغيل: ثلاث فجوات مختلفة

1
ملاءمة التصميم

هل الضابط، كما صُمّم، يغطي الخطر والنطاق المطلوبين؟

الدليل: نص الإجراء أو المعيار، ونطاقه، ومقارنته بالخطر والأنظمة.

←

2
التنفيذ

هل طبقت الجهة الضابط فعلاً كما صُمّم؟

الدليل: أول تشغيل: إعداد، أو ملف، أو تذكرة بتاريخ.

←

3
فاعلية التشغيل

هل عمل وفق تصميمه، وبالتكرار المطلوب، طوال الفترة؟

الدليل: أدلة تغطي الفترة كلها: كل دورة، وكل عينة.

اسأل بالترتيب: لا معنى لاختبار تشغيل ضابط سيئ التصميم، أو ضابط لم يُطبق بعد.

مثال محلول (1 من 2): فجوة تصميم وفجوة تنفيذ

1. فجوة تصميم · البريد والملفات السحابية

ما صُمّم ووُثّق

إجراء مراجعة الصلاحيات: «يراجع مدير كل إدارة حسابات موظفي إدارته كل ستة أشهر».

الدليل

تصدير الحسابات: 203 حسابات، منها 4 حسابات إدارية لا تتبع أي إدارة: admin01، admin02، vendor-admin، svc-backup.

الاستنتاج

لا مدير يراجع الحسابات الإدارية، فهي خارج المراجعة بالتصميم. ولو نُفذ الإجراء بإتقان لبقيت أخطر الحسابات بلا مراجعة.

2. فجوة تنفيذ · تطبيق تتبع الشحنات

ما صُمّم ووُثّق

معيار التحكم بالوصول، المعتمد في مارس: يضيف تطبيق التتبع، ومراجعة شاملة لكل حساباته كل 3 أشهر، وأولها قبل نهاية أبريل.

الدليل

لا ملف مراجعة ولا تصدير لمستخدمي التطبيق. بريد من تقنية المعلومات في يوليو: «لم نحدد بعد من يصدّر قائمة المستخدمين».

الاستنتاج

الضابط مصمم وموثق ومعتمد، لكنه لم يُطبق مرة واحدة. لا معنى لاختبار فاعليته قبل أن يبدأ.

مثال محلول (2 من 2): فجوة تشغيل، ولماذا يهمك النوع

3. فجوة تشغيل · نظام الموارد البشرية والرواتب

ما صُمّم ووُثّق

المعيار نفسه: مراجعة صلاحيات الرواتب كل 3 أشهر، يعتمدها مالك النظام.

الدليل

مراجعة الربع الأول منفذة ومعتمدة في 8 أبريل. لا ملف لمراجعة الربع الثاني حتى نهاية يونيو.

الاستنتاج

الضابط صُمم جيداً وطُبق فعلاً، لكنه لم يعمل بالتكرار المطلوب طوال الفترة.

نوع الفجوة	العلاج المناسب	في المثال
تصميم	تعديل الإجراء أو المعيار ليغطي الخطر والنطاق.	إضافة الحسابات الإدارية إلى مراجعة البريد بمراجع محدد.
تنفيذ	بدء التطبيق: مالك، وأداة، وموعد أول تشغيل.	تحديد من يصدّر مستخدمي تطبيق التتبع، وتنفيذ أول مراجعة.
تشغيل	استعادة الدورة المفقودة، ومتابعة تمنع التكرار.	مراجعة الربع الثاني، وجدول بتذكير آلي.

تمرين: ما نوع الفجوة؟

لكل موقف: ما نوع الفجوة: تصميم، أم تنفيذ، أم تشغيل؟ ولماذا؟ وما الدليل الذي يؤكد استنتاجك؟ 10 دقائق.

#	الموقف	نوع الفجوة ولماذا	الدليل
1	معيار الوصول عن بعد يفرض MFA على كل مستخدمي VPN، لكنه يسمح بـ«استثناءات مؤقتة» دون موافقة ولا مدة.		
2	سياسة الأطراف الخارجية المعتمدة في مايو تطلب بند إبلاغ عن الحوادث في كل عقد، ولم يُعدَّل عقد مورد الدعم ولم يُرسل له ملحق.		
3	معيار النسخ يطلب نسخة يومية لخادم التتبع، والمهمة مضبوطة يومياً، لكن تقرير المهام يُظهر 9 أيام فاشلة متتالية في مايو دون متابعة.		

الإجابة: ما نوع الفجوة؟

النوع	لماذا	الدليل الذي يؤكده
1. فجوة تصميم	الضابط كما كُتب يترك باباً مفتوحاً: استثناء بلا موافقة ولا مدة، فقد يبقى حساب بلا MFA إلى الأبد.	نص المعيار، وقائمة الاستثناءات القائمة وتواريخها.
2. فجوة تنفيذ	المتطلب مكتوب ومعتمد، لكنه لم يُطبق على العقد القائم.	السياسة المعتمدة، والعقد الحالي، وأي مراسلة أو خطة لتعديله.
3. فجوة تشغيل	الضابط مصمم ومطبق، لكنه توقف 9 أيام دون أن يلاحظ أحد.	تقرير مهام النسخ للفترة كلها، وتذاكر المتابعة إن وُجدت.

⚠ خطأ شائع: تسمية كل فجوة «فجوة تشغيل». السؤال الأول دائماً: هل التصميم يغطي الخطر؟

المؤشرات: KGI وKPI وKRI وKCI

KGI

مؤشر تحقق الهدف

هل تحقق هدف العمل؟

مثال: نسبة إتاحة تطبيق التتبع الشهرية، والالتزام 99%.

KPI

مؤشر الأداء

هل تُنفَّذ العملية جيداً؟

مثال: متوسط أيام العمل لإغلاق تذاكر إزالة الصلاحيات، والمعيار 5.

KRI

مؤشر الخطر

هل يرتفع التعرض للخطر؟

مثال: عدد الثغرات الحرجة المفتوحة أكثر من 14 يوماً في خادم التتبع.

KCI

مؤشر الضابط

هل يعمل الضابط كما صُمّم؟

مثال: نسبة مراجعات الصلاحيات المعتمدة في موعدها.

⚠ التصنيف بالغرض، لا بالرقم: المؤشر نفسه قد يكون KPI في جهة وKCI في أخرى. اكتب في تعريفه ماذا يقيس، ولماذا.

تعريف المؤشر: ستة أسئلة قبل أي رقم

	KGI · إتاحة التتبع	KPI · إغلاق تذاكر الإزالة	KRI · الثغرات الحرجة	KCI · مراجعات الصلاحيات
ماذا يقيس	إتاحة تطبيق التتبع للمتاجر.	سرعة إزالة الصلاحيات بعد اعتمادها.	تعرض خادم التتبع للاستغلال.	هل تعمل المراجعة الدورية؟
الحساب	ساعات الإتاحة ÷ ساعات الشهر × 100.	متوسط أيام العمل من الاعتماد إلى الإغلاق.	عدد الحرجة المفتوحة أكثر من 14 يوماً.	المعتمدة في موعدها ÷ المجدولة × 100.
المصدر	تقرير المراقبة الشهري من المورد.	نظام التذاكر.	تقرير فحص الثغرات.	ملفات المراجعة وجدولها.
المالك	مدير تقنية المعلومات	مدير تقنية المعلومات	مدير تقنية المعلومات، والمورد ينفذ	مالكو الأنظمة، وتجمعه GRC
الدورية	شهري	شهري	شهري	ربع سنوي
يستدعي إجراءً	أقل من 99%: سبب وخطة خلال أسبوع.	أكثر من 5 أيام عمل.	أكبر من صفر. ويُصعَّد للجنة إن تجاوز عمرها 30 يوماً.	أقل من 100%.

تقرير الإدارة (1 من 2): المخاطر والمؤشرات

تقرير ربع سنوي للجنة · 1 من 2
لجنة الأمن السيبراني · الربع الثالث · مسؤول GRC

نموذج تعليمي · بيانات افتراضية

1. أهم المخاطر

الخطر	المستوى	الحالة	المالك
تأخر ترقيع ثغرات خادم التتبع	16 · عالٍ	ينتظر قرار الكلفة	مدير التقنية
حساب إداري مشترك يستخدمه المورد	16 · عالٍ	3 من 5 إجراءات منجزة	مدير التقنية
ملفات الرواتب على حاسوب غير مشفر	6 · منخفض	عولج: الجهاز مشفر	مديرة الموارد البشرية

2. المؤشرات

المؤشر	القيمة	المرجع	الحالة
KGI · إتاحة التتبع	99.4%	الهدف 99%	ضمن الحد
KPI · إغلاق تذاكر الإزالة	3.2 يوم عمل	المعيار 5	ضمن الحد
KRI · ثغرات حرجة أكثر من 14 يوماً	3	الحد صفر	يتجاوز الحد
KCI · مراجعات الصلاحيات في موعدها	100%	الربع الثالث	ضمن الحد

تقرير الإدارة (2 من 2): الملاحظات والإجراءات والقرارات

تقرير ربع سنوي للجنة · 2 من 2
لجنة الأمن السيبراني · الربع الثالث · مسؤول GRC

نموذج تعليمي · بيانات افتراضية

3. الملاحظات المتأخرة والمفتوحة

الملاحظة	الوضع	الموعد
MFA غير مفعل لثلاثة حسابات VPN	3 من 4 إجراءات منجزة.	في موعدها
مراجعة صلاحيات الرواتب	جدول المراجعات السنوي لم يُعتمد بعد.	متأخر 20 يوماً

4. حالة إجراءات التصحيح

5
منجزة

2
جارية في موعدها

1
متأخرة

5. القرارات المطلوبة من اللجنة

1. اعتماد كلفة ترقيع عاجل لخادم التتبع خارج العقد الحالي.
2. إضافة مهلة الترقيع وبند الإبلاغ عن الحوادث إلى عقد المورد عند تجديده.

أداة GRC: كيف ترتبط المتطلبات والضوابط والأدلة والمخاطر

سجل GRC · ورقة الربط · Excel
نموذج تعليمي · بيانات افتراضية

المتطلب	الضابط	الدليل	الخطر	الملاحظة	الإجراء
ECC 2-2-3-5	CTL-AC-03 مراجعة الرواتب الفصلية	EV-21 ملف المراجعة · EV-22 التذاكر	R-12 صلاحيات غير مبررة	F-04	CAP-04-1 إلى 4
ECC 2-2-3-2	CTL-RA-01 MFA على VPN	EV-11 الإعداد · EV-13 المطابقة	R-09 دخول بكلمة مرور فقط	F-03	CAP-03-1 إلى 4
ECC 4-1-2	CTL-TP-02 بنود عقود الموردين	EV-31 عقد المورد	R-15 حساب المورد المشترك	—	خطة المعالجة

رقم واحد يربط كل شيء: من الملاحظة F-04 تصل إلى المتطلب والضابط والدليل والخطر والإجراءات. المنصات المتخصصة تفعل الشيء نفسه بجداول مرتبطة.

مخاطر الأطراف الخارجية: من التقييم إلى الإنهاء

حين تُسند خدمة إلى مورد، ينتقل جزء من العمل، ولا تنتقل المسؤولية.

1
قبل التعاقد

تقييم المخاطر: ما الخدمة، وما البيانات والوصول؟ (ECC 4-1-3-1)

خطأ شائع: التقييم بعد التوقيع.

الدليل: تقرير التقييم وتصنيف المورد.

2
العقد

السرية وحذف البيانات، والإبلاغ عن الحوادث، والالتزام بالسياسات (ECC 4-1-2).

خطأ شائع: بند سرية فقط.

الدليل: العقد وملاحقه.

3
الوصول

حسابات فردية بأقل صلاحية وMFA، وسجلات تُراجع.

خطأ شائع: حساب مشترك لكل فني المورد.

الدليل: قائمة حسابات المورد وسجلاتها.

4
المتابعة

مراجعة دورية للأداء والالتزام وتحديث التقييم (ECC 4-1-4).

خطأ شائع: لا مراجعة بعد التوقيع.

الدليل: محاضر المراجعة وتقارير المورد.

5
الإنهاء

إلغاء الصلاحيات، وإعادة البيانات وحذفها الآمن.

خطأ شائع: حساب المورد نشط بعد انتهاء العقد.

الدليل: محضر الإنهاء وتأكيد الحذف.

⚠ قدرة الجهة على فرض الشروط تضعف بعد التوقيع: التقييم والعقد أهم مرحلتين.

مجالان ستقابلهما مبكراً: الاستمرارية والخصوصية

استمرارية الأعمال

تحليل أثر الأعمال (BIA) يحدد أهم الخدمات، وكم تتحمل الجهة توقفها.



مثال: نظام الرواتب، RTO = 24 ساعة، وRPO = 4 ساعات. إذن نحتاج نسخة احتياطية كل 4 ساعات على الأقل، وخطة استعادة مجربة.

حماية البيانات الشخصية

في المملكة: **نظام حماية البيانات الشخصية (PDPL)**، والجهة المختصة سدايا.

- ✓ أساس نظامي لكل معالجة، وغرض محدد، وأقل قدر من البيانات
- ✓ حقوق لصاحب البيانات: العلم، والوصول، والتصحيح، والإتلاف
- ✓ سجل لأنشطة المعالجة، وتقييم أثر للمعالجات عالية المخاطر
- ✓ إبلاغ الجهة المختصة عن حوادث التسرب خلال مدة محددة

وفي أوروبا: اللائحة العامة لحماية البيانات (GDPR).

BIA وBCP وDRP والحوادث: أين يقف GRC؟

BIA

تحليل أثر الأعمال

ما أهم الخدمات؟ وكم تتحمل الجهة توقفها؟ ومنه RTO وRPO.

مثال: الرواتب: RTO 24 ساعة، وRPO 4 ساعات.

BCP

خطة استمرارية الأعمال

كيف تستمر الخدمة المهمة أثناء التوقف، ومن يقرر؟

مثال: إجراء بديل معتمد لصرف الرواتب إن تعذر النظام.

DRP

خطة التعافي من الكوارث

كيف تُستعاد الأنظمة والبيانات تقنياً، وبأي ترتيب؟

مثال: استعادة بيانات الرواتب من النسخ خلال 24 ساعة.

IR

الاستجابة للحوادث

اكتشاف الحادثة واحتواؤها والتعافي منها، والإبلاغ عنها.

مثال: تسرب من خادم التتبع: من يُبلَّغ، ومتى.

ما يفعله GRC

- ✓ يتأكد أن الخطط موجودة ومعتمدة ومختبرة.
- ✓ يربط نتائج الاختبار والحوادث بسجل المخاطر والملاحظات.

ما لا يفعله

- ⚠ لا يقود الاستجابة الفنية للحادثة.
- ⚠ لا يكتب خطة التعافي التقنية بدل أصحابها.

قاموس: 12 مصطلحاً ستراها في كل إعلان

سجل المخاطر Risk Register
قائمة المخاطر بمالكها ودرجتها ومعالجتها

شهية المخاطر Risk Appetite
مقدار الخطر الذي تقبله الإدارة

الخطر المتبقي Residual Risk
ما يبقى من الخطر بعد الضوابط

مؤشر المخاطر الرئيسي KRI
رقم ينبه مبكراً إلى ارتفاع خطر

تقييم الفجوات Gap Assessment
مقارنة الوضع القائم بمتطلبات إطار

بيان قابلية التطبيق SoA
أي ضوابط ISO 27001 تنطبق ولماذا

مالك الضابط Control Owner
المسؤول عن تطبيق الضابط وأدلته

ضابط تعويضي Compensating Control
بديل حين يتعذر الضابط الأصلي

استثناء Policy Exception
إعفاء موثق ومؤقت من متطلب

فصل المهام SoD
لا ينفذ شخص واحد العملية ويعتمدها

أقل صلاحية Least Privilege
صلاحيات بقدر حاجة العمل فقط

العناية الواجبة Due Diligence
التحقق من المورد أو الشريك قبل التعامل

04 الأطر والمعايير

لا تحتاج أن تحفظ كل الأطر. تحتاج أن تعرف ماذا يفعل كل إطار، ولمن هو، وبأيها تبدأ.

خريطة الأطر العالمية | ISO/IEC 27001 | NIST CSF 2.0 | الأطر السعودية | بأي إطار تبدأ؟ | أنواع المراجع

CSF مقابل RMF | مراجع القطاع والبيانات | مراجع للتعريف | المواءمة

نظام، وضوابط، وإطار، ومعيار، وضابط: ما الفرق؟

النوع	هل هو ملزم؟ وما هو؟	مثال
نظام أو تشريع	ملزم بقوة القانون لمن يقع في نطاقه	نظام حماية البيانات الشخصية
ضوابط تنظيمية	ملزمة للجهات التي يحددها نطاقها	ECC-2:2024 للجهات المشمولة
إطار	يرشد ويرتب العمل، وغالباً طوعي	NIST CSF 2.0
معيار قابل للشهادة	طوعي، تُمنح عليه شهادة من جهة مانحة	ISO/IEC 27001
التزام تعاقدي	ملزم بالعقد لا بالقانون	PCI DSS عبر العقود مع شبكات البطاقات
ضابط	إجراء أو إعداد محدد يحقق متطلباً	MFA للدخول عن بعد

السؤال الأول دائماً: هل هذا المرجع ملزم لهذه الجهة تحديداً، أم اختارته طوعاً؟

خريطة الأطر العالمية: كل إطار يجيب عن سؤال

نظام إدارة يُمنح شهادة

كيف ندير الأمن بشكل مستمر؟

ISO/IEC 27001
أمن المعلومات

ISO 22301
استمرارية الأعمال

ISO/IEC 27701
إدارة الخصوصية

أطر مخاطر وضوابط

ماذا نطبق، وبأي ترتيب؟

NIST CSF 2.0
لغة مشتركة لإدارة المخاطر

NIST SP 800-53
كتالوج ضوابط تفصيلي

CIS Controls
18 ضابطاً مرتبة بالأولوية

حوكمة التقنية

هل تخدم التقنية أهداف الجهة؟

COBIT 2019
من ISACA: أهداف حوكمة وإدارة

COSO
الرقابة الداخلية وإدارة المخاطر المؤسسية

قطاعية وتعاقدية

ماذا يطلب العميل أو القطاع؟

PCI DSS
لمن يعالج بيانات البطاقات

SOC 2
تقرير تأكيد لمزودي الخدمات

GDPR
حماية البيانات في أوروبا

الأطر تتداخل كثيراً. ضابط واحد، مثل التحقق متعدد العوامل، قد يحقق متطلبات في عدة أطر معاً. هذا الربط اسمه «المواءمة».

ISO/IEC 27001:2022 في شريحة واحدة

الجزء الإلزامي: البنود 4 إلى 10

4 السياق والنطاق	**5** القيادة والسياسة	**6** التخطيط وتقييم المخاطر	**7** الدعم والموارد
8 التشغيل ومعالجة المخاطر	**9** تقييم الأداء والتدقيق الداخلي	**10** التحسين المستمر	

مسار الشهادة

تدقيق المرحلة 1 (الوثائق) ← المرحلة 2 (التطبيق) ← شهادة لثلاث سنوات، مع تدقيق متابعة سنوي.

الملحق A: 93 ضابطاً في 4 محاور



لا تطبق كل الضوابط تلقائياً: تختار ما يلزم من تقييم المخاطر، وتبرر الاستبعاد في بيان قابلية التطبيق (SoA).

NIST CSF 2.0: ست وظائف، والحوكمة في المركز

GV

الحوكمة · Govern

وظيفة جديدة في الإصدار 2.0

الاستراتيجية، والأدوار، والسياسات، وإدارة مخاطر سلسلة الإمداد. هنا يعمل GRC بشكل مباشر.

ID
التحديد
الأصول، والمخاطر، وفرص التحسين

PR
الحماية
الهويات، والتوعية، وأمن البيانات والمنصات

DE
الاكتشاف
المراقبة المستمرة وتحليل الأحداث

RS
الاستجابة
إدارة الحادثة، والتواصل، والاحتواء

RC
التعافي
استعادة الأصول والعمليات

الملف التعريفي (Profile): وضعك الحالي مقابل الوضع المستهدف، والفرق خطة عمل.

المستويات (Tiers): من 1 جزئي إلى 4 متكيف، تصف نضج إدارة المخاطر.

مقارنتان تخلطهما المقابلات

NIST CSF أم NIST RMF؟

	CSF 2.0	RMF
النوع	إطار نتائج لإدارة مخاطر الأمن السيبراني	عملية من سبع خطوات
المستوى	الجهة كلها: ملفات ومستويات	نظام واحد عبر دورة حياته
المرجع	CSWP 29 · 2024	SP 800-37 Rev. 2

تقييم الفجوات أم النضج؟

	Gap Assessment	Maturity Assessment
السؤال	ما الفرق بين الوضع القائم ومتطلب محدد؟	إلى أي مستوى وصلت ممارسات الجهة؟
النتيجة	قائمة فجوات: مطبق، جزئي، غير مطبق	مستوى على مقياس نضج
مثال	مقارنة الجهة بضوابط ECC	قياس مستوى إدارة المخاطر من 1 إلى 5

خطوات RMF السبع: Prepare · Categorize · Select · Implement · Assess · Authorize · Monitor

الأطر السعودية: من يصدرها، وعلى من تنطبق

الهيئة الوطنية للأمن السيبراني (NCA)

ECC-2:2024	الضوابط الأساسية: 108 ضوابط، للجهات الحكومية وجهات البنية التحتية الوطنية الحساسة
CCC-2:2024	الحوسبة السحابية: لمقدمي الخدمات السحابية والمستفيدين منها
DCC-1:2022	البيانات: حماية البيانات في دورة حياتها
CSCC-1:2019	الأنظمة الحساسة الوطنية
OTCC-1:2022	أنظمة التقنية التشغيلية والتحكم الصناعي
TCC-1:2021	العمل عن بعد
OSMACC-1:2021	حسابات التواصل الاجتماعي للجهات

البنك المركزي السعودي (ساما)

إطار الأمن السيبراني (SAMA CSF)، الإصدار 1.0 لعام 2017، للبنوك وشركات التأمين والتمويل الخاضعة لإشرافه.

سدايا ومكتب إدارة البيانات الوطنية

نظام حماية البيانات الشخصية ولوائحه، و**معايير إدارة البيانات** الوطنية.

للمسار المهني: الإطار السعودي لكوادر الأمن السيبراني (SCyWF-1.5:2026) فيه فئة للحوكمة والمخاطر والامتثال بأدوارها.

مراجع القطاع والبيانات: لمن تنطبق؟

المرجع ونوعه	الغرض	نطاق الانطباق	لماذا قد تستخدمه الجهة؟
إطار ساما (2017): إطار تنظيمي قطاعي	الأمن السيبراني في القطاع المالي	الخاضعون لإشراف البنك المركزي: البنوك، والتأمين، والتمويل، ومكاتب الائتمان، وغيرها	ملزم لهم، ويُطلب من مزوديهم أحياناً
نظام حماية البيانات الشخصية: نظام (قانون)	حقوق صاحب البيانات وضوابط معالجتها	معالجة البيانات الشخصية المتعلقة بأفراد في المملكة، ومنها المعالجة من خارجها	ملزم لمن يقع في نطاقه، ومنه أغلب الشركات
PCI DSS v4.0.1: معيار تعاقدي من مجلس PCI SSC	حماية بيانات البطاقات	من يخزن بيانات البطاقات أو يعالجها أو ينقلها	تفرضه شبكات البطاقات والبنوك المستحوذة بالعقود
GDPR: لائحة أوروبية	حماية البيانات الشخصية	منشأة في الاتحاد الأوروبي، أو من يعرض سلعاً وخدمات لأفراد فيه أو يراقب سلوكهم	شركة سعودية تخدم عملاء في أوروبا

مراجع للتعريف والمقارنة

المرجع ونوعه	الغرض	نطاق الانطباق	لماذا قد تستخدمه الجهة؟
COBIT 2019: إطار حوكمة وإدارة للتقنية من ISACA	ربط التقنية بأهداف الجهة	أي جهة، طوعاً	لحوكمة التقنية وتدقيقها
CIS Controls v8.1: ضوابط مرتبة بالأولوية من CIS	18 ضابطاً و153 إجراءً، ومجموعات تنفيذ IG1 إلى IG3	أي جهة، طوعاً	بداية عملية: IG1 «النظافة السيبرانية الأساسية»
NIST RMF: عملية لإدارة مخاطر الأنظمة من NIST	سبع خطوات من التهيئة إلى المراقبة	مصممة للأنظمة الفيدرالية الأمريكية	منهجية لإدارة مخاطر نظام عبر دورة حياته
HIPAA: قانون أمريكي	حماية المعلومات الصحية	خطط التأمين الصحي ومقدمو الرعاية المشمولون وشركاؤهم	جهة تعالج بيانات صحية لصالح جهة أمريكية
SOX: قانون أمريكي (2002)	موثوقية التقارير المالية	الشركات المدرجة في الولايات المتحدة؛ القسم 404 للرقابة الداخلية	ضوابط التقنية التي تمس التقارير المالية

مثال محلول: مواءمة ضابط واحد مع مرجعين

الضابط الداخلي: CTL-RA-01: التحقق متعدد العوامل إلزامي لكل مستخدمي VPN (معيار الوصول عن بعد).

المرجع	ماذا يطلب، بإيجاز	ماذا يغطي الضابط الداخلي	التغطية
ECC 2-2-3-2	تحقق متعدد العوامل للدخول عن بعد وللحسابات ذات الصلاحيات الهامة، بعوامل يحددها تقييم الأثر.	يغطي الدخول عن بعد عبر VPN فقط.	**جزئي: الحسابات الهامة لها ضابط آخر يجب ربطه.**
ISO/IEC 27001 A.8.5	المصادقة الآمنة: تقنيات وإجراءات مصادقة آمنة وفق قيود الوصول.	جزء منها: MFA على VPN.	**جزئي: يخدم جزءاً من الضابط.**

الأدلة: إعداد سياسة البوابة، وسجل التغييرات، وسجل الاتصالات بطريقة التحقق: الأدلة نفسها تخدم المرجعين.

المواءمة توفر الجهد، لكنها لا تثبت الالتزام: إن كان الضابط مطبقاً جزئياً، فالنتيجة جزئية في المرجعين معاً.

تمرين: مواءمة مراجعة الصلاحيات

الضابط الداخلي: CTL-AC-03: مراجعة صلاحيات نظام الرواتب كل 3 أشهر، وإزالة غير المبرر خلال 5 أيام عمل.

المرجع	ماذا يطلب، بإيجاز	ماذا يغطي الضابط الداخلي	التغطية
ECC 2-2-3-5	المراجعة الدورية لهويات الدخول والصلاحيات.		
ISO/IEC 27001 A.5.18	صلاحيات الوصول: منحها ومراجعتها وتعديلها وإزالتها.		

أكمل: ماذا يغطي الضابط من كل مرجع؟ كلي أم جزئي، ولماذا؟ وما الأدلة التي تخدم الاثنين؟ 10 دقائق.

الإجابة: مواءمتان جزئيتان

المرجع	التغطية	لماذا
ECC 2-2-3-5	جزئي	الضابط يغطي نظام الرواتب فقط. المتطلب يشمل هويات الدخول والصلاحيات في كل الأنظمة، فالبريد وVPN وتطبيق التتبع تحتاج ضوابط مراجعة أخرى.
ISO A.5.18	جزئي	الضابط يخدم المراجعة والإزالة، ولا يغطي منح الصلاحيات وتعديلها.
الأدلة	مشتركة	ملف المراجعة واعتماده يخدمان المراجعة في المرجعين، وتذاكر الإزالة تخدم الإزالة في ISO.

⚠ لا تكتب «متوافق» لأن العنوانين متشابهان. اكتب ما يغطيه الضابط، وما ينقص، وأي دليل يثبت ماذا.

بأي إطار تبدأ؟ ترتيب مقترح، وطريقة مذاكرة

1

NIST CSF 2.0 · الصورة الكاملة

مجاني، وقصير نسبياً، ويعطيك هيكلاً تعلق عليه كل ما بعده.

2

ISO/IEC 27001 · نظام الإدارة

البنود 4 إلى 10 تعلمك كيف «يدار» الأمن، وهو الأكثر طلباً في الإعلانات.

3

إطار القطاع الذي تستهدفه

حكومي: ECC. بنوك: SAMA CSF. مدفوعات: PCI DSS. سحابة: CCC.

مع كل ضابط تقرؤه، اسأل:

1. ما الخطر الذي يعالجه؟
2. كيف يبدو تطبيقه في جهة حقيقية؟
3. ما الدليل الذي يثبت تطبيقه؟
4. ما الذي يقابله في إطار آخر؟

من يجيب عن هذه الأسئلة الأربعة يفهم الضابط، ولا يكتفي بحفظه.

05

الشهادات

أي شهادة تناسب مرحلتك؟ ماذا تشترط، وكم تكلف، وكيف تذاكر لها، ومتى لا تحتاجها أصلاً.

خريطة المسار · شهادات البداية · شهادات GRC وISO · ISACA · ISC2 · الخصوصية · مقارنة شاملة · كيف تختار · كيف تذاكر

خريطة الشهادات: ثلاث مراحل، لا تقفز للأخيرة

1

البداية

بلا خبرة. تثبت أنك تعرف الأساسيات.

CC	ISC2
Security+	CompTIA
IT Risk Fundamentals	ISACA

2

التخصص

مهارة محددة في GRC أو معيار بعينه.

ISO 27001 LI / LA	جهات تدريب
GRCP	OCEG
CIPP/E · CIPM	IAPP

3

المتقدم

تشترط سنوات خبرة قبل منحها.

CISA · CRISC · CISM	ISACA
CGRC · CISSP	ISC2
CGEIT · CDPSE	ISACA

شهادات البداية: بلا خبرة سابقة

CC — Certified in Cybersecurity

ISC2 · أول شهادة لحديث التخرج

الخبرة	لا يشترط خبرة
الاختبار	100 إلى 125 سؤالاً في ساعتين، تكيفي (CAT)، والنجاح 700 من 1000
الرسوم	199 دولاراً للاختبار، ثم 50 دولاراً سنوياً بعد النجاح
التجديد	45 ساعة تعليم مستمر (CPE) كل 3 سنوات

⚠ انتهى عرض الاختبار المجاني، وأُغلق التسجيل فيه في 20 مايو 2026.

SEC+ — CompTIA Security+

CompTIA · أساس تقني أوسع

الخبرة	لا شرط رسمي؛ يُنصح بـ Network+ وسنتين في الأنظمة أو الأمن
الاختبار	حتى 90 سؤالاً في 90 دقيقة، منها أسئلة أداء عملية، والنجاح 750 من 900
الرسوم	تختلف حسب الدولة. **لم نتحقق** من السعر الرسمي
التجديد	كل 3 سنوات: 50 وحدة تعليم مستمر و150 دولاراً

⚠ إصدار جديد SY0-801 نحو 17 نوفمبر 2026، والحالي SY0-701 يتوقف بالإنجليزية في 11 يونيو 2027.

وأيضاً: IT Risk Fundamentals من ISACA، شهادة إتمام بلا شروط، واختبار عن بعد مدته ساعتان، بـ 175 دولاراً للأعضاء و225 لغيرهم.

شهادات متخصصة في GRC ومعيار ISO 27001

GRCP — GRC Professional

OCEG · مدخل متخصص في GRC

الخبرة	لا يشترط خبرة ولا شهادة جامعية
الاختبار	100 سؤال محتسب في 120 دقيقة، عن بعد وبكتاب مفتوح، والنجاح 70 سؤالاً
الرسوم	ضمن اشتراك OCEG: 499 دولاراً أول سنة، ثم 399 سنوياً
التجديد	مع الاشتراك، و8 ساعات CPE سنوياً من السنة الثانية

⚠ صفحة OCEG تذكر قاعدتين مختلفتين للتجديد؛ اسألهم قبل الشراء.

27001 — ISO 27001 Lead Implementer / Auditor

PECB مثالاً · LI للتطبيق، LA للتدقيق

الخبرة	درجة «Provisional» بالاختبار فقط. لقب «Lead» يحتاج 5 سنوات، منها سنتان في إدارة أمن المعلومات
الاختبار	80 سؤالاً، بكتاب مفتوح، والنجاح 70%
الرسوم	حسب جهة التدريب. بلا تدريب عند PECB: 1,000 دولار للاختبار و500 للطلب
التجديد	كل 3 سنوات، بساعات تطوير مهني ورسم سنوي

💡 الدورة 5 أيام عادة. وجهات أخرى، مثل BSI، تقدمها بشروط مختلفة.

ISACA (1 من 2): التدقيق والمخاطر

CISA — Certified Information Systems Auditor

ISACA · تدقيق تقنية المعلومات

الخبرة	5 سنوات في تدقيق النظم أو الرقابة أو الأمن، خلال آخر 10 سنوات؛ إعفاء حتى 3 سنوات
الاختبار	150 سؤالاً في 4 ساعات، والنجاح 450 من 800
الرسوم	575 دولاراً للأعضاء و760 لغيرهم، و50 لطلب الشهادة
التجديد	20 ساعة CPE سنوياً و120 كل 3 سنوات، ورسم سنوي 45 دولاراً للأعضاء أو 85

تستطيع أن تختبر الآن، ثم تقدم طلب الشهادة خلال 5 سنوات من النجاح.

CRISC — Risk and Information Systems Control

ISACA · مخاطر تقنية المعلومات

الخبرة	3 سنوات في مخاطر تقنية المعلومات والرقابة، في مجالين من 4؛ بلا إعفاء
الاختبار	150 سؤالاً في 4 ساعات، والنجاح 450 من 800
الرسوم	575 دولاراً للأعضاء و760 لغيرهم، و50 لطلب الشهادة
التجديد	مثل CISA: 20 ساعة سنوياً و120 كل 3 سنوات، ورسم سنوي

الأقرب لوظائف المخاطر في GRC. أكبر مجال فيه: الاستجابة للمخاطر والتقارير، 32%.

ISACA (2 من 2): الإدارة والحوكمة

CISM — Certified Information Security Manager

ISACA · إدارة أمن المعلومات

الخبرة	5 سنوات في إدارة أمن المعلومات، في 3 مجالات من 4؛ إعفاء حتى سنتين
الاختبار	150 سؤالاً في 4 ساعات، والنجاح 450 من 800
الرسوم	575 دولاراً للأعضاء و760 لغيرهم، و50 لطلب الشهادة
التجديد	20 ساعة CPE سنوياً و120 كل 3 سنوات، ورسم سنوي

⚠ مخطط اختبار جديد من 3 نوفمبر 2026؛ راجع المجالات الجديدة قبل المذاكرة.

CGEIT — Governance of Enterprise IT

ISACA · حوكمة تقنية المعلومات للقيادات

الخبرة	5 سنوات في إدارة حوكمة تقنية المعلومات أو الاستشارة أو الإشراف عليها؛ بلا إعفاء
الاختبار	150 سؤالاً في 4 ساعات، والنجاح 450 من 800
الرسوم	575 دولاراً للأعضاء و760 لغيرهم، و50 لطلب الشهادة
التجديد	20 ساعة CPE سنوياً و120 كل 3 سنوات، ورسم سنوي

للمستوى القيادي بعد سنوات، ومرتبطة بإطار COBIT.

ISC2: الحوكمة والمخاطر، ثم القيادة

CGRC — Governance, Risk and Compliance

ISC2 · كانت تسمى CAP حتى 2023

الخبرة	سنتان في مجال واحد على الأقل من 7؛ يُحتسب الدوام الجزئي والتدريب
الاختبار	125 سؤالاً في 3 ساعات، والنجاح 700 من 1000
الرسوم	599 دولاراً للاختبار، ثم 135 سنوياً
التجديد	60 ساعة CPE كل 3 سنوات

تنجح بلا خبرة فتصبح Associate of ISC2، ولديك 3 سنوات لتكملها.

CISSP — Information Systems Security Professional

ISC2 · للمستوى القيادي في الأمن

الخبرة	5 سنوات في مجالين من 8؛ درجة أو شهادة معتمدة تعوض سنة
الاختبار	100 إلى 150 سؤالاً في 3 ساعات، تكيفي (CAT)
الرسوم	749 دولاراً للاختبار، ثم 135 سنوياً
التجديد	120 ساعة CPE كل 3 سنوات

بلا خبرة تصبح Associate ولديك 6 سنوات. مخطط اختبار جديد من 15 أبريل 2027.

شهادات الخصوصية وحماية البيانات

CIPP/E — IAPP
قانون الخصوصية الأوروبي GDPR

الخبرة
لا شرط مذكور

الاختبار
90 سؤالاً في ساعتين ونصف

الرسوم
550 دولاراً للأعضاء وغيرهم

التجديد
20 ساعة CPE و250 دولاراً كل سنتين، أو عضوية 295 سنوياً

CIPM — IAPP
إدارة برنامج الخصوصية في الجهة

الخبرة
لا شرط مذكور

الاختبار
90 سؤالاً في ساعتين ونصف

الرسوم
550 دولاراً للأعضاء وغيرهم

التجديد
مثل CIPP/E: كل سنتين

CDPSE — ISACA
الهندسة التقنية للخصوصية

الخبرة
3 سنوات في الخصوصية، بلا إعفاء

الاختبار
120 سؤالاً في 3 ساعات ونصف

الرسوم
575 دولاراً للأعضاء و760 لغيرهم

التجديد
20 ساعة CPE سنوياً، ورسم 45 أو 85 دولاراً

شهادات IAPP مبنية على GDPR. كثير من مبادئه قريبة من النظام السعودي، لكنها لا تغني عن قراءة نظام حماية البيانات الشخصية ولوائحه.

المقارنة: كم سنة خبرة تحتاج، وكم تدفع؟

0 بلا خبرة

CC	199
Security+	غير مؤكد
IT Risk Fund.	225
GRCP	499 اشتراك
CIPP/E	550
CIPM	550
ISO 27001	حسب الجهة

2 سنتان

CGRC	599

3 سنوات

CRISC	760
CDPSE	760

5 سنوات

CISA	760
CISM	760
CGEIT	760
CISSP	749

الأرقام رسم الاختبار لغير الأعضاء بالدولار. وفي أعمدة الخبرة تستطيع أن تختبر أولاً: ISC2 تمنحك صفة Associate، وISACA تمهلك 5 سنوات لتقديم الطلب.

كيف تختار: ابدأ من الوظيفة، لا من الشهادة

الوظيفة المستهدفة	مدخل	تخصص	بعد اكتمال الخبرة
محلل GRC وامتثال الخط الثاني	CC أو Security+	← ISO 27001 LI أو GRCP	← CRISC أو CGRC
مدقق تقنية معلومات الخط الثالث	CC أو IT Audit Fund.	← ISO 27001 LA	← CISA
الخصوصية وحماية البيانات مثل مسؤول حماية البيانات	CC	← CIPP/E أو CIPM	← CDPSE
قيادة الأمن والحوكمة هدف بعيد، بعد سنوات	أي مسار مما سبق	← CISSP أو CISM	← CGEIT

☆ شهادة واحدة لكل مرحلة. ما بين المراحل خبرة ومشاريع، لا شهادة إضافية.

كيف تذاكر لأي شهادة: أربع خطوات

1

مخطط الاختبار الرسمي

Exam Outline مجاني. المجالات وأوزانها هي خطة مذاكرتك.

2

مصدر أساسي واحد

الدليل الرسمي أو دورة معتمدة. خمسة مصادر تشتت ولا تضيف.

3

بنك أسئلة بفهم

لكل سؤال: لماذا الصحيح صحيح، ولماذا كل خيار آخر خطأ.

4

احجز حين تثبت درجاتك

حين تتجاوز حد النجاح في الاختبارات التجريبية مرة بعد مرة.

فكّر كمدير

أسئلة ISACA وISC2 تسأل عن «الأفضل» أو «الأول» من منظور المخاطر والإدارة، لا الحل التقني الأسرع.

الاختبار بالإنجليزية

لا يقدم أي اختبار في هذه الوحدة بالعربية. ذاكر المصطلحات بالإنجليزية من اليوم الأول.

طابق المخطط وموعدك

مخططات CC وCISM وSecurity+ وCISSP تتغير بين 2026 و2027. مادتك يجب أن تطابق مخطط يوم اختبارك.

06

الخطة العملية

الخبرة هي العائق الأكبر للمبتدئ. هنا تصنع دليلاً على قدرتك قبل أول وظيفة.

خطة 90 يوماً | مشاريع لملف أعمالك | المهارات المطلوبة

الوحدة 06 · الخطة العملية

خطة 90 يوماً: من الصفر إلى أول طلب توظيف

مبنية على 8 إلى 10 ساعات أسبوعياً تقريباً. عدّلها حسب وقتك.

الأساس

الأيام 1 إلى 30

- ✓ أنهِ الوحدتين 2 و3 من هذا الكورس
- ✓ اقرأ NIST CSF 2.0 كاملاً
- ✓ ابدأ مذاكرة CC أو Security+
- ✓ أنشئ حساب LinkedIn بصورة وعنوان مبدئي

المخرَج: ملخص بكلماتك لكل مفهوم في الوحدتين 2 و3.

التطبيق

الأيام 31 إلى 60

- ✓ نفّذ مشروعين من مشاريع الشريحة التالية
- ✓ اقرأ إطار قطاعك المستهدف
- ✓ احجز اختبار شهادة البداية وقدّمه
- ✓ انشر أول منشور عن ما تعلمته

المخرَج: مشروعان منشوران، وشهادة أولى أو موعد اختبار.

السوق

الأيام 61 إلى 90

- ✓ اضبط السيرة وLinkedIn (الوحدتان 6 و7)
- ✓ قدّم على وظائف مناسبة كل أسبوع
- ✓ محادثتان تعريفيتان أسبوعياً مع مختصين
- ✓ جهّز 5 قصص بطريقة STAR

المخرَج: طلبات مقدمة، وشبكة تعرفك، وجاهزية للمقابلة.

ستة مشاريع تصنع لك خبرة قبل الوظيفة

01 سجل مخاطر

20 خطراً لشركة افتراضية، بالدرجة والمالك والمعالجة.

يثبت: تقييم المخاطر

02 تقييم فجوات

مكوّن واحد من ECC أو بنود ISO 27001، مع خطة معالجة.

يثبت: فهم الأطر

03 حزمة وثائق

سياسة ومعيار وإجراء لموضوع واحد، مثل إدارة الصلاحيات.

يثبت: الكتابة المهنية

04 تقييم مورد

استبيان من 25 سؤالاً، وتحليل ردود مورد افتراضي.

يثبت: مخاطر الأطراف الخارجية

05 مصفوفة مواءمة

20 ضابطاً من ECC وما يقابلها في ISO 27001 وNIST CSF.

يثبت: العمل بعدة أطر

06 تقرير تدقيق مصغر

5 ملاحظات بالعناصر الخمسة: الوضع، والمعيار، والسبب، والأثر، والتوصية.

يثبت: الأدلة والتقارير

انشر: قسم «مميز» في LinkedIn، أو GitHub، أو رابط عام في Drive.

جهة افتراضية دائماً. لا تنشر بيانات أو وثائق جهة حقيقية.

المهارات المطلوبة، وكيف تتدرب على كل واحدة

مهارات المجال

قراءة الأطر	الأسئلة الأربعة مع كل ضابط
تقييم المخاطر	مشروع سجل المخاطر
أساسيات تقنية	الشبكات، والهويات، والسحابة: من مذاكرة Security+
Excel	الجداول المحورية، والتنسيق الشرطي، وXLOOKUP
منصات GRC	اعرف فكرتها: سجلات، وتقييمات، وسير عمل، ولوحات

مهارات شخصية، وغالباً هي الفارق

الكتابة الواضحة	أعد كتابة ملاحظة في 3 أسطر بدل 10
شرح التقني لغير التقني	اشرح خطراً لصديق خارج المجال في دقيقة
الإقناع	اربط كل توصية بأثر على العمل، لا بالمتطلب وحده
المتابعة والتنظيم	تتبع مشاريعك بمالك وموعد، كما تتبع الملاحظات
النزاهة والسرية	لا مجاملة في التقييم، ولا إفشاء لما تطلع عليه

والإنجليزية: أغلب المعايير والمصادر والاختبارات بها. اقرأ يومياً ولو صفحة واحدة.

07

السيرة الذاتية

سيرة تقرؤها الأنظمة والبشر معاً، وتقول «أستطيع أن أفعل» لا «أنا مهتم».

هيكل السيرة | أنظمة الفرز ATS | صياغة الإنجازات | بلا خبرة؟ | أخطاء شائعة

تشريح سيرة مبتدئ في GRC

Sara Ahmed
GRC Analyst | Cybersecurity Compliance 1
Riyadh · sara.ahmed@email.com · linkedin.com/in/sara-ahmed-grc

SUMMARY 2
Entry-level GRC analyst with hands-on risk assessment and NCA ECC-2:2024 gap analysis projects. ISC2 CC.

SKILLS 3
Risk Assessment · Gap Analysis · ISO 27001 · NIST CSF · NCA ECC · Excel

PROJECTS 4
Risk Register · Fictional logistics company, 200 staff
• Scored 20 risks on a 5×5 matrix; wrote treatment plans for the top 6.
ECC Gap Assessment · Same company
• Assessed one ECC subdomain; documented 5 findings with owners.

EDUCATION
B.Sc. Information Systems, 2025

CERTIFICATIONS 5
ISC2 CC, 2026

1. **العنوان** نفس مسمى الوظيفة التي تستهدفها.
2. **ملخص** في سطرين: من أنت، وماذا تجيد، وأقوى دليل.
3. **المهارات** بكلمات الإعلان نفسها.
4. **المشاريع** قبل التعليم إن لم تكن لديك خبرة. كل سطر: فعل ثم نتيجة.
5. **الشهادات** باسمها والسنة. «قيد الدراسة» مع موعد متوقع مقبولة.

صفحة واحدة للمبتدئ. بلا صورة ولا عمر ولا حالة اجتماعية، إلا إن طلبها الإعلان.

أنظمة الفرز (ATS): أول قارئ لسيرتك آلة

ترسل السيرة ← يستخرج النص ← يطابق كلمات الإعلان ← يرتب المتقدمين ← يقرأ موظف التوظيف

افعل

- ملف Word أو PDF نصي، لا صورة ممسوحة
- عناوين قياسية: Experience، Education، Skills
- نفس مصطلحات الإعلان إن كانت صادقة عنك
- عمود واحد، وخط عادي، ومعلومات الاتصال في متن الصفحة

تجنب

- نصوصاً داخل صور أو مربعات نص
- أعمدة وجداول معقدة للتنسيق
- أشرطة تقييم المهارات: «Excel ★★★★☆»
- حشو كلمات مفتاحية لا تعرفها؛ المقابلة ستكشفها

تمرين المطابقة

Conduct **risk assessments** and support **ISO 27001** and **NCA ECC** compliance. Maintain **policies**.

ظلّل مصطلحات الإعلان، ثم تأكد أن كل مصطلح صادق عنك موجود في سيرتك.

صياغة الإنجاز: قبل وبعد

المعادلة: فعل قوي + ماذا فعلت + بأي طريقة أو أداة + النتيجة أو الرقم

BEFORE Responsible for the risk register.

AFTER Built a 20-risk register on a 5×5 matrix for a fictional 200-staff company; prioritized 6 high risks with treatment plans.

BEFORE Familiar with ISO 27001.

AFTER Mapped 30 ISO/IEC 27001:2022 Annex A controls to NCA ECC-2:2024 requirements, identifying 8 coverage gaps.

BEFORE Worked on the IT help desk.

AFTER Processed 25+ weekly access requests per the approval workflow; flagged 3 over-privileged accounts for review.

أفعال مناسبة لـ GRC: Assessed · Mapped · Drafted · Reviewed · Tracked · Remediated

بلا خبرة في GRC؟ خبرتك أقرب مما تظن

ترجم خلفيتك إلى لغة GRC

الدعم الفني	← طلبات الصلاحيات، وسير الموافقات، والبلاغات
المحاسبة والتدقيق	← الرقابة الداخلية، والأدلة، والعينات
القانون	← الأنظمة واللوائح، والعقود، والخصوصية
إدارة الجودة	← أنظمة الإدارة، والتدقيق الداخلي، والإجراءات
إدارة المشاريع	← متابعة المعالجة بمالك وموعد، وتقارير الحالة

أقسام تملأ مكان «الخبرة»

- ✓ **Projects:** مشاريع الوحدة 6
- ✓ **Internship:** التدريب التعاوني، ولو قصيراً
- ✓ **Volunteering:** كتابة سياسة لجمعية أو نادٍ
- ✓ **Capstone:** مشروع التخرج إن كان قريباً

كل ما تكتبه حقيقي وتستطيع شرحه في المقابلة.

ثمانية أخطاء شائعة، وتصحيح كل منها

الخطأ	التصحيح
سيرة من ثلاث صفحات أو أكثر	صفحة واحدة للمبتدئ، وصفحتان كحد أقصى مع الخبرة
«Responsible for...» في كل سطر	فعل + ما فعلت + طريقة + نتيجة
أخطاء إملائية في وظيفة تقوم على الدقة	مدقق إملائي، ثم قراءة شخص آخر
نسخة واحدة لكل الإعلانات	عدّل الملخص والمهارات لكل إعلان مهم
شهادة لم تحصل عليها	ما حصلت عليه فقط، أو «قيد الدراسة» مع موعد
«Team player, hard worker» بلا دليل	مهارة مع دليل: مشروع، أو رقم، أو نتيجة
بريد غير مهني أو قديم	بريد باسمك، ورابط LinkedIn مخصص
رقم الهوية أو الجواز في السيرة	الاسم والمدينة ووسائل التواصل تكفي

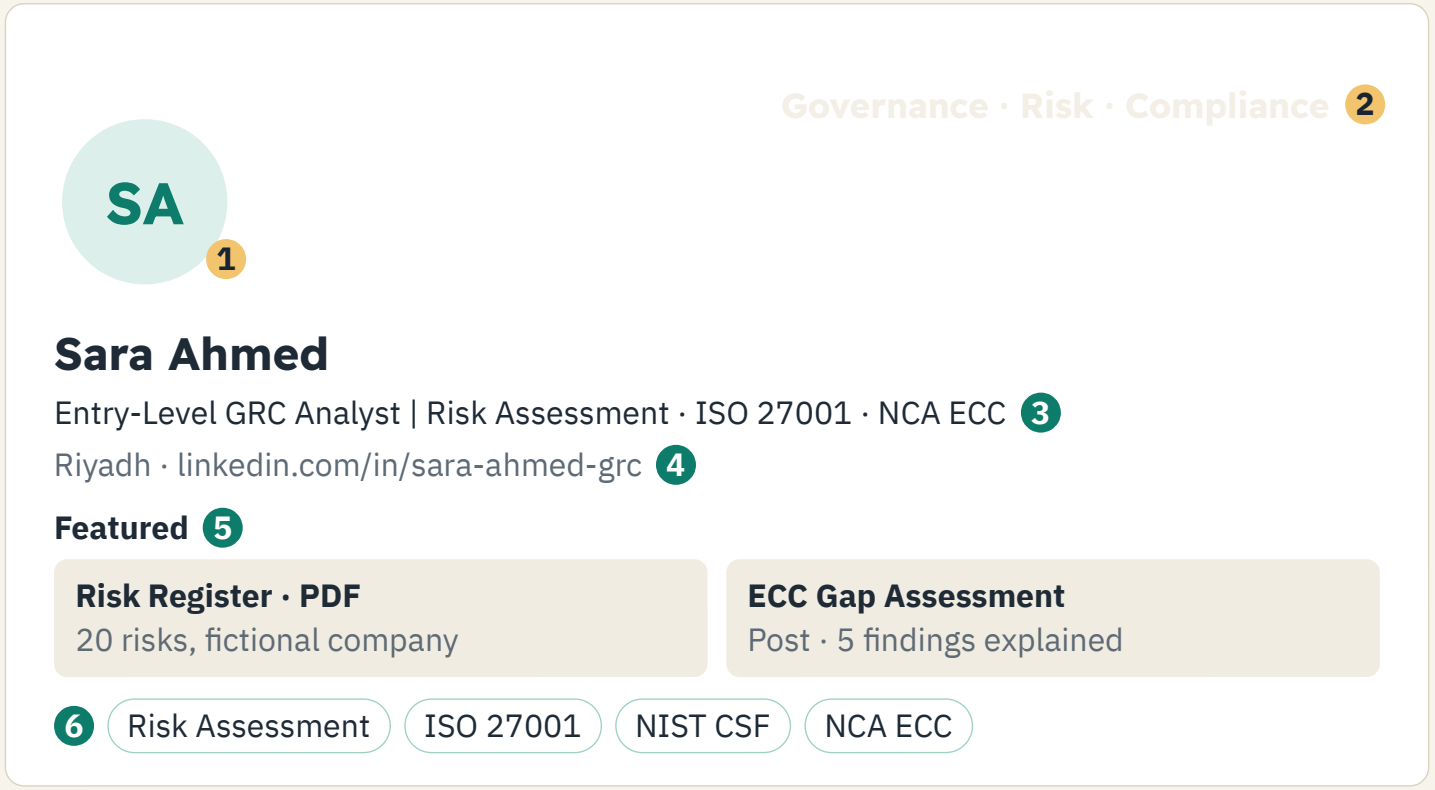
08 LinkedIn

ملفك على LinkedIn يعمل وأنت نائم: يجده مسؤول التوظيف حين يبحث، ويقرؤه قبل أن يتصل بك.

تشريح الملف · العنوان المهني · نبذة About · بناء الشبكة والنشر · البحث عن الوظائف

تشريح ملف مكتمل

1. **الصورة:** وجه واضح وخلفية بسيطة. من 400×400 بكسل، حتى 8 ميغابايت.
2. **الخلفية:** المقاس الموصى به 1584×396 بكسل.
3. **العنوان المهني:** الوظيفة المستهدفة وكلماتها، لا «طالب» فقط.
4. **رابط مخصص:** من 3 إلى 100 حرف، بلا مسافات ولا رموز.
5. **Featured:** مشاريعك من الوحدة 6 أعلى الملف.
6. **المهارات:** حتى 100 مهارة. ضع أهمها في الأعلى.



العنوان المهني: أهم سطر في ملفك

المعادلة: الوظيفة المستهدفة | مجالان أو ثلاثة | دليل: شهادة أو مشروع

ضعيف

Computer Science Student

Looking for opportunities

Cybersecurity enthusiast | Hard worker

لا يحتوي كلمة يبحث بها مسؤول التوظيف.

قوي

Entry-Level GRC Analyst | Risk Assessment · ISO 27001 · NCA ECC | ISC2 CC

IT Support → GRC | Access Management · NIST CSF 2.0 | Security+

محلل حوكمة ومخاطر وامتثال | ECC · ISO 27001 | مشروعا تقييم فجوات

الكلمات المهمة في البداية، وكل كلمة صادقة عنك.

نبذة About: أربعة أجزاء في فقرات قصيرة

About

Entry-level GRC analyst focused on turning security requirements into clear, testable controls.

Recent work: a 20-risk register for a fictional logistics company, and an NCA ECC-2:2024 gap assessment with 5 documented findings and owners.

Focus: risk assessment · ISO/IEC 27001 · NIST CSF 2.0 · policy writing · ISC2 CC · Arabic and English.

Open to entry-level GRC and compliance roles in Riyadh. Message me or see my projects in Featured.

1. الافتتاح
من أنت، وما الذي تركز عليه.

2. الدليل
مشروعان بنتائج محددة.

3. المجالات والأطر
كلمات البحث التي تريد أن تظهر بها.

4. الدعوة
ماذا تبحث عنه، وكيف يتواصلون معك.

الحد 2,600 حرف، لكن 150 إلى 250 كلمة تكفي غالباً.

الشبكة والنشر: كن مرئياً في مجالك

من تضيف، وكيف

- مختصو GRC في الجهات التي تستهدفها
- مسؤولو التوظيف في الأمن السيبراني
- زملاء الدراسة والدورات والفعاليات

رسالة طلب تواصل قصيرة

«أ. نورة، قرأت منشورك عن تقييم الموردين واستفدت منه. أنا في بداية مساري في GRC وأعمل على مشروع سجل مخاطر، ويسعدني التواصل.»

ماذا تنشر

1. ضابط واحد شرحته بمثال من الواقع
2. مشروع من ملف أعمالك مع ما تعلمته منه
3. خلاصة فعالية أو ورشة حضرتها
4. تعليق مفيد على منشور مختص، لا «شكراً» فقط

⚠ لا تنشر أي تفصيل عن ضوابط أو ثغرات جهة عملت أو تدربت فيها.

البحث عن الوظائف: «Open to Work» والكلمات الصحيحة

فعّل «Open to Work»

Me → View profile → Open to → Finding a new job

كل الأعضاء	مسؤولو التوظيف فقط
يراه الجميع، ويضيف إطار #OpenToWork على صورتك.	لا تضمن LinkedIn إخفاءه تماماً عن جهتك الحالية.

حدد المسميات، والمدن، ونوع العمل: حضوري أو عن بعد.

ابحث بأكثر من مسمى

GRC Analyst · Cybersecurity Compliance · IT Risk Analyst

IT Auditor · Security Controls Assessor · Cybersecurity Policy Officer

محلل حوكمة ومخاطر

- فعّل تنبيه وظائف لكل مسمى، وقدّم مبكراً.
- تابع صفحات الجهات المستهدفة، وقدّم أيضاً من مواقعها مباشرة.
- بعد التقديم، رسالة قصيرة لمختص في الفريق نفسه.

09

المقابلة والانطلاق

كل ما تعلمته يُختبر في ساعة واحدة. استعد لها كما تستعد لاختبار الشهادة.

أسئلة المقابلة · طريقة STAR · قائمة المراجعة · الخطوة التالية

ثمانية أسئلة متوقعة، وأين جوابها في الكورس

«ما الفرق بين التهديد والثغرة والخطر؟»
يختبر: المفاهيم الأساسية
الشريحة 25

«كيف تقيّم خطراً وترتبه مع غيره؟»
يختبر: الاحتمال والأثر والمنهجية
الشريحة 32

«ما الفرق بين السياسة والمعيار والإجراء؟»
يختبر: هرم الوثائق
الشريحة 40

«كيف تتأكد أن ضابطاً مطبق فعلاً؟»
يختبر: الأدلة والعينات
الشريحة 52

«مالك نظام يرفض تطبيق ضابط. ماذا تفعل؟»
يختبر: الإقناع، والبدائل، والاستثناء
الشريحتان 37 و66

«اشرح ECC أو ISO 27001 لمدير غير تقني»
يختبر: التبسيط والفهم
الشريحتان 70 و73

«ما الفرق بين الامتثال والمراجعة الداخلية؟»
يختبر: نموذج الخطوط الثلاثة
الشريحة 50

«لماذا GRC؟ ولماذا جهتنا تحديداً؟»
يختبر: دافعك وبحثك عن الجهة
جهّزه بنفسك

طريقة STAR: قصة قصيرة بنتيجة واضحة

السؤال: «حدثنا عن مرة اكتشفت فيها مشكلة لم ينتبه لها أحد.» والجواب مثال توضيحي.

S الموقف

في تدريبي التعاوني، كانت مراجعة صلاحيات نظام المالية متأخرة ثمانية أشهر.

T المهمة

كُلفت بتجهيز قائمة المستخدمين للمراجعة.

A ما فعلته أنا

صدّرت القائمة من النظام، وقارنتها بسجل الموارد البشرية، فوجدت 6 حسابات لموظفين غادروا، ورفعتها لمالك النظام مع مقترح.

R النتيجة

أُلغيت الحسابات الستة خلال أسبوع، واعتُمدت مراجعة ربع سنوية.

دقيقة إلى دقيقتين لكل إجابة

«أنا» في الإجراء، لا «نحن»

جهّز 5 قصص مسبقاً

قائمة المراجعة: هل أنت جاهز للتقديم؟

المعرفة

- [ ] أشرح مصطلحات المخاطر الستة بمثال
- [ ] أفرق بين السياسة والمعيار والإجراء
- [ ] قرأت NIST CSF 2.0 كاملاً
- [ ] أعرف الأطر التي تنطبق على قطاعي

الشهادة

- [ ] اخترت شهادة مدخل واحدة
- [ ] قرأت مخطط اختبارها الرسمي الحالي
- [ ] تحققت من الرسوم في موقعها
- [ ] حجزت موعداً أو حصلت عليها

الدليل

- [ ] مشروعان منشوران على الأقل
- [ ] صفحة «ماذا تعلمت» لكل مشروع
- [ ] لا بيانات لجهة حقيقية فيها
- [ ] أستطيع شرح كل مشروع في دقيقتين

السوق

- [ ] سيرة صفحة واحدة بإنجازات
- [ ] LinkedIn: صورة، وعنوان، ونبذة، وFeatured
- [ ] 5 قصص STAR جاهزة
- [ ] قائمة بعشرين جهة تستهدفها

نهاية الكورس، وبداية المسار

ابدأ هذا الأسبوع بثلاث خطوات

لا تنتظر أن تكتمل الصورة. خطوة صغيرة كل أسبوع، ودليل تراه أنت وغيرك.

1 **اختر شهادة المدخل**
واقرأ مخطط اختبارها الرسمي

2 **ابدأ سجل المخاطر**
أول مشروع في ملف أعمالك

3 **حدّث عنوانك في LinkedIn**
بالمعادلة من الشريحة 103

الأسعار والشروط والإصدارات كما في 27 أكتوبر 2026. تحقق منها في المواقع الرسمية قبل التسجيل.